

PUBLIC • TRAINING GUIDE

SOC 2 COMPLIANCE

Comprehensive Training & Implementation Guide

Mohammad Shamim

Cloud Security Architect | Cybersecurity Specialist

July 2026

Trust Services Criteria • Audit Readiness • Controls & Governance

Document Control

Document identification, authorship, and distribution details.

Document Information

Document Name	SOC 2 Compliance — Comprehensive Training & Implementation Guide
Author	Mohammad Shamim
Role / Title	Cloud Security Architect Cybersecurity Specialist
Version	1.0
Date	29 July 2026
Classification	Public

Version History

Version	Date	Author	Description	Status
1.0	29 July 2026	Mohammad Shamim	Initial formatted release — restructured, styled, and consolidated for publication.	Final

Purpose

A reference guide covering SOC 2 Trust Services Criteria, audit planning, control implementation, and the audit lifecycle — from scoping through closing and follow-up.

Table of Contents

1. Introduction to SOC 2	6
1.1 What is SOC 2 Compliance?.....	6
1.2 AICPA COSO Framework.....	6
1.3 Trust Service Criteria ('TSC') and Point of Focus	7
1.4 Audit Timeline & period	9
1.4 Audit Timeline & period	9
1.5 Certification bodies	11
2. The Planning Phase –	12
2.1 Defining The Audit Scope	12
2.2 Creation of the System Description	13
2.3 Types of Controls	14
2.4 Gap Analysis	15
2.5 Identifying Gaps and Remediation.....	16
2.6 Creation and Mapping of Controls.....	16
2.7 Choosing the Auditing Firm-	17
3.Framework Subject Matters	19
3.1 Control Environment.....	19
3.2 Communication and Information.....	20
3.3 Risk Assessment.....	21
3.4 Monitoring Activities.....	22
3.5 Control Activities.....	23
3.6 Logical and Physical Access Controls.....	24
3.7 System Operations	26
3.8 Change Management.....	28
3.9 Risk Mitigation	29
3.10 Additional Criteria for Availability	29
3.10 Additional Criteria for Confidentiality	29
3.11 Additional Criteria for Processing Integrity	31
3.12 Additional Criteria for Privacy.....	33
4: Prepare For Implementation	36

4.1 Shared Responsibility Model	36
4.2 Key Stakeholder Identification	36
4.3 Technical, Procedural, and Administrative Controls Implementation	37
4.4 Prioritization	37
5. Security Management Procedures	39
5.1 Policies and Procedures	39
5.2 Passwords and MFA	39
5.3 Risk Assessment	40
5.4 Risk Mitigation	42
5.5 User Access Review	43
5.6 Security Awareness Training	44
5.7 Security Risk Vs Security Vulnerabilities	45
5.8 Endpoint Management and Anti-Malware	46
5.9 Assets Mapping and Classification	48
5.10 Human Resources	50
5.11 Maintenance, Monitoring, and Analysis of Audit Logs	53
5.12 Data Breaches and Disclosures	55
5.13 Crisis Management	58
5.14 Segregation of Duties and Least Privilege	59
5.15 Change Management	60
5.16 Internal Audit	61
6. Initiating a SOC 2 Audit	63
6.1 Audit Principles and Concepts	63
6.2 Preparation of Audit	65
6.3 Trust but Verify Approach - Audit Evidence	66
6.4 Types of Audit Procedures Performed	68
6.5 Documentation	70
7. Monitoring, Control, and Completing SOC 2 Project Plan	71
7.1 Automation of Controls	71
7.2 Real-time Identification of Non-Compliance Issues	71
7.3 Response and Records of Non-Compliance Issues	72
8. Conducting a SOC 2 Audit	73
8.1 Communication During An Audit	73
8.2 Audit Procedures and Evaluation of Evidence - Auditors' Point of View	74

8.3 Drafting Audit Plans	74
8.4 Audit Findings and Deviations	75
9. Closing the Audit and Follow-Up	76
9.1 Audit Closing Procedure	76
9.2 Organizing a Closing Meeting and Stating The Conclusion of The Audit.....	76
9.3 Auditors Opinion Results	76
9.4 Deviations and Management's Response.....	77
9.5 Complementary User Entity Controls (CUECs).....	77
9.6 Sub Service Organizations Carved Out Controls	77
9.7 Corrective Action Plans For The Following Audit Cycle	78
9.8 Marketing Aspects and Logo Use.....	78

1. Introduction to SOC 2

1.1 What is SOC 2 Compliance?

SOC Definition

SOC stands for Service Organization Controls (SOC). The controls you design and implement inside your control environment vary based upon the people, technology, and products your company develops.

Service organizations have a responsibility to protect the customer data they collect, as well as the products they develop and build. Customers of service organizations rely heavily on the organization providing a safe, secure, and reliable platform to help conduct business.

You can think of the products or solutions an organization develops and provides as one small piece of the puzzle within other organizations' infrastructure and operating procedures. Compiling many of these services together is what helps a business operate and thrive.

Example

Imagine a business that provides a SaaS solution that helps organizations onboard new employees and takes them through the onboarding process. This solution would collect personal information such as names, social security numbers, telephone numbers, and email addresses. The product or service the organization provides needs to be implemented securely, and the organization's customers will want assurance that the company is operating effectively while protecting their data.

History of SOC Reports



Figure A.1 — Progression of SOC 2 Reporting Standards

1.2 AICPA COSO Framework

What is the COSO Framework?

The COSO Framework is a framework for designing, implementing, and monitoring internal controls to be incorporated into business processes. It also provides a level of assurance that the organization is ethically sound, transparent in its operating procedures, and aligned with the best practices in industry.

What makes up the framework?

The framework consists of five different components, along with three internal objectives.

The three internal objectives the COSO Framework aims to achieve are the following:

1. Operations Objectives
2. Reporting Objectives
3. Compliance Objectives

The five components that help achieve the objectives above are the following:

1. Control Environment
2. Risk Assessment
3. Control Activities
4. Information & Communication
5. Monitoring Activities

Risk assessments should be actively taking place in the organization. This will include a subset of controls such as evaluating vendor risk and software vendors. In today's fast-paced business world security assessments often comes in the form of a security questionnaire. Which is then evaluated by the business from a security perspective. Alternatively, businesses are also requesting attestation reports such as a SOC 2, or ISO 270001 report before deciding between vendors.

Monitoring activities come in the form of many different processes and procedures. However, with regards to SOC 2, there are two different types. Administrative, and technical. As we continue through this course you will start to see and notate the difference between administrative and technical controls.

1.3 Trust Service Criteria ('TSC') and Point of Focus

What are Trust Service Criteria?

The Trust Service Criteria (TSC) are the overall criteria that your organization will be audited on. The organization will have gone over the criteria beforehand with the auditor.

Alternatively, if you're an auditor, you will go over the Trust Service Criteria with your client to ensure that a proper scope has been defined before the auditing period begins. The Trust Service Criteria are listed below.



The Five Trust Services Criteria

When reviewing the Trust Services Criteria, it is important to note that not all of the trust service criteria have to be met in order to obtain a satisfactory SOC 2 report. However, the business has to meet the objectives that have been defined as part of the scope between the business and the auditing firm. At a minimum, the business will need to comply with the common criteria.

Description of TSC

Security — Ensuring that the information systems and data are protected against unauthorized access and disclosure. Also make sure that damage from malicious software doesn't impact your information systems to the extent that it would impact confidentiality, integrity, or availability. Also known as the CIA triad.

Availability — Ensuring that your information systems are operational during normal operating hours, and their intended use is not impacted by your organization's processes.

Processing Integrity — The system or solution that has been developed processes information correctly, in a timely manner, and encompasses proper authorization when doing so — meaning proper access is defined and reports or data cannot be accessed by a user who doesn't have the appropriate access rights.

Confidentiality — Information that has been classified as confidential is secure within the documented scope of information systems and is free from tampering or misuse.

Privacy — Customer or personal information that is obtained, used, disclosed, or retained is properly obtained using legal methods, such as a DPA, contract, or data sharing agreement. The organization should also have a policy and process in place for collection methods and data deletion.

Points of Focus

Now let's talk about the points of focus — what they are, and how you, as a lead implementer, will be responsible for not only communicating what the points of focus are but also ensuring customers understand what it is they are trying to accomplish.

Overview — Points of Focus

Points of focus are intended for you, as a SOC implementer or consultant, to help customers achieve controls that are suitable to their organization. Think of points of focus like helpful hints, tips, and tricks regarding what the control is trying to prevent, mitigate, or detect. Organizations pursuing a SOC 2 attestation do not have to comply with all of the points of focus — it's important to understand that these are not requirements.

Example

Let's review an example of a point-of-focus statement.

Figure A.2

TSP Ref. #	TRUST SERVICES CRITERIA AND POINTS OF FOCUS
	CONTROL ENVIRONMENT
CC1.1	COSO Principle 1: The entity demonstrates a commitment to integrity and ethical values.
	The following points of focus highlight important characteristics relating to this criterion:
	Points of focus specified in the COSO framework:

Figure A.2 — CC1: COSO Principle 1

“The entity demonstrates a commitment to integrity and ethical values.”

The following points of focus, specified in the COSO framework, highlight important characteristics relating to this criterion.

When reviewing Figure A.2, you can see how the Trust Service Criteria, the related COSO component (control environment), the common criteria, and the point of focus are laid out together.

1.4 Audit Timeline & period

Figure A.3 - Hints

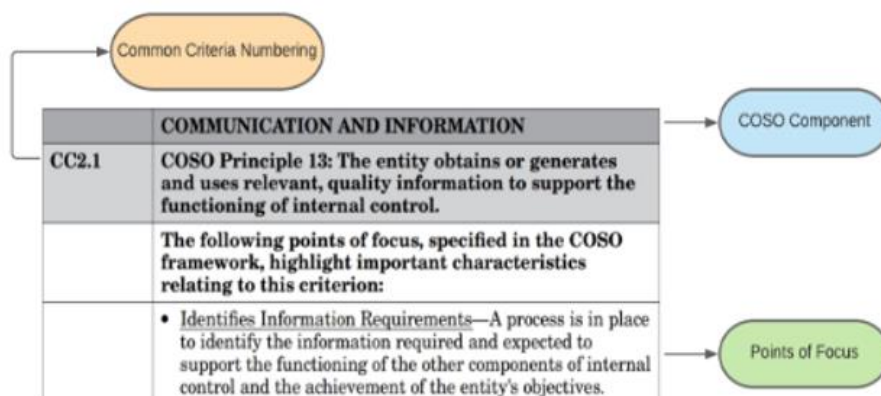


Figure A.3 — CC2.1: COSO Principle 13

“The entity obtains or generates and uses relevant, quality information to support the functioning of internal control.”

- Identifies Information Requirements — a process is in place to identify the information required and expected to support the functioning of the other components of internal control and the achievement of the entity's objectives.

Point of Focus Example

Figure A.4

	System Operations
CC7.1	<i>To meet its objectives, the entity uses detection and monitoring procedures to identify (1) changes to configurations that result in the introduction of new vulnerabilities, and (2) susceptibilities to newly discovered vulnerabilities.</i>
	The following points of focus, specifically related to all engagements using the trust services criteria, highlight important characteristics relating to this criterion:
	• <i>Uses Defined Configuration Standards—Management has defined configuration standards.</i>
	• <i>Monitors Infrastructure and Software—The entity monitors infrastructure and software for noncompliance with the standards, which could threaten the achievement of the entity's objectives.</i>

Figure A.4 — Configuration & Monitoring

To meet its objectives, the entity uses detection and monitoring procedures to identify (1) changes to configurations that result in the introduction of new vulnerabilities, and (2) susceptibilities to newly discovered vulnerabilities.

- Uses Defined Configuration Standards — management has defined configuration standards.
- Monitors Infrastructure and Software — the entity monitors infrastructure and software for noncompliance with the standards, which could threaten the achievement of the entity's objectives.

There are two points of focus mentioned above in Figure A.4:

1. Uses Defined Configuration Standards
2. Monitors Infrastructure and Software

Breaking down the points of focus: using the scope that was defined earlier in the audit engagement, you, as a SOC 2 Lead Implementer, should know what information systems and processes are in scope.

The first point of focus talks about configuration management — the configuration standards for the information systems that are in scope.

The second point of focus refers to infrastructure and monitoring of software. The organization should be monitoring system outages, or more specifically, when the CIA triad is violated. It should also be monitoring what type of software is deployed in the environment.

1.4 Audit Timeline & period

SOC 2 Type 1 & 2 Auditing Periods

Different types of SOC audits have different audit timelines and audit periods. For example, a SOC 2 Type 1 report has a minimum auditing period of 3 months, while a SOC 2 Type 2 report has a minimum audit period of 6 months.

Typically, an organization will first obtain a SOC 2 Type 1 report as a metric to see where the organization stands when it comes to its people, processes, and technology. Then there are the organizations that are more mature — mature in their processes, systems, and technology.

Audit Timelines

Timelines will vary greatly between organizations. However, several key metrics are used to determine how much work needs to be completed before an audit period begins. One of these key metrics is a gap analysis; another is a risk assessment. The risk assessment should also identify gaps where controls could be missing or processes are deficient. For now, please review the high-level overview of the audit lifecycle below.

Figure B.1 - Overview of Audit Lifecycle

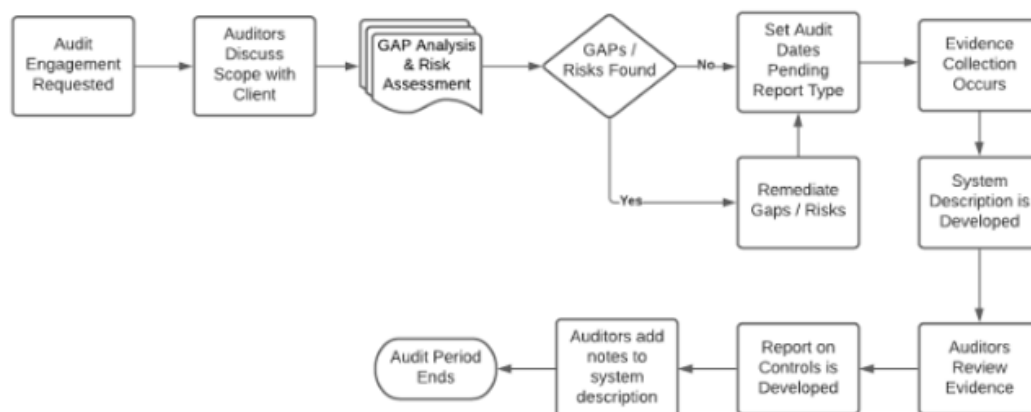




Figure B.1 — Overview of the Audit Lifecycle

The above diagram does not depict every process in an audit; it provides a high-level overview of what to expect during the audit lifecycle and is meant to be used as a guide. Every auditing firm, consultant, and lead implementer will have its own processes and techniques for completing the audit.

1.5 Certification bodies

There are only a few entities that can provide attestation rights for a SOC 2 Report. These business entities are usually professional organizations that have years of experience in tax advisory services, or the law. Review the list below of common types of organizations that can attest to a SOC 2 Report. Please note, although SOC 2 compliance encompasses a majority of cyber-security-related controls, the final attestation must be provided by a licensed and qualified Certified Public Accountant (CPA).

Example

Acme Law Corporation wants to add an IT Services and audit branch to its current service offerings and start performing SOC 2 audits. They must have a qualified CPA that can attest to the SOC 2 report and provide an auditor's opinion on the design and suitability of controls that have been developed.

It's important to note that auditors or firms must go through a review process every three years. This is a must in order to keep the status of an aud

2. The Planning Phase –

2.1 Defining The Audit Scope

Scope

Prior to the engagement with an auditing firm or service auditor, the management at the service organization should have properly defined the system scope. However, with smaller organizations, that is not always the case. This is where part of your responsibilities as a Lead Implementer or consultant will come into play. Let's review the following basic responsibilities when determining scope;

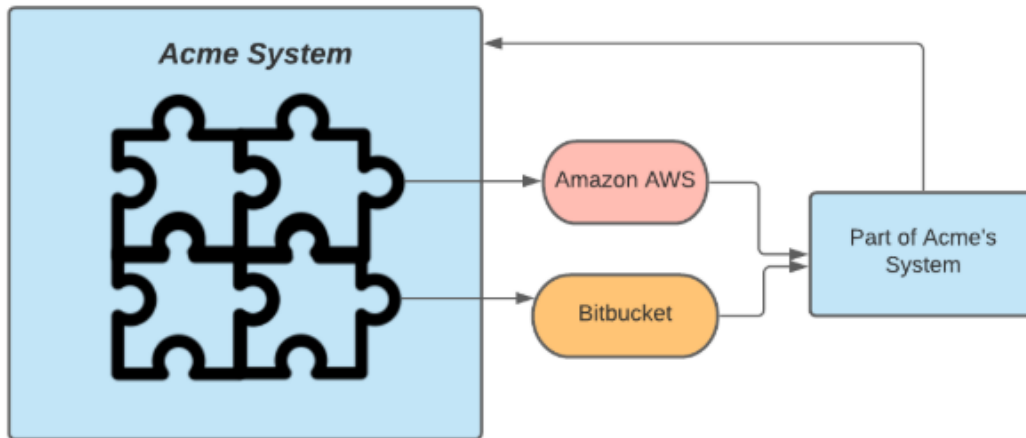
1. Identification of services provided to customers
2. Identification of system(s) used to provide services
3. Identification of business partners or consultants that provide copyrights, patents or Intellectual property or services to the system(s)
4. Defining and selecting the Trust Services Categories to be included in the scope of attestation.
5. Defining if the organization should undergo a Type I or Type II SOC 2 audit.
6. Defining the "As of Date" as notated for a SOC 2 Type 1 Report
7. Determining if sub-service organizations/sub-level services are a part of the overall system and if they need to be included in the attestation report.
8. Identifying and analyzing risks that hinder a service organization from its service commitments of defined SLA's.
9. Obtaining system-level requirements as they relate to business partners.

The list above is a great reference when assisting customers on their journey through the SOC 2 audit process. Please notate it and use it as a reference when working with customers. Now that you have an understanding of basic requirements for defining the system scope. Let's take a closer look at sub-service organizations, and what they are.

Looking at Figure C.1 "Displayed Below" - The blue shaded large square represents "Acme Corps System" the puzzle pieces within the system would be considered sub-service organizations under SOC 2.

As noted it appears that one of the pieces of the puzzle is made of up Amazon AWS, and the other Bitbucket. Amazon could be providing hosting or infrastructure resources needed to run "Acme's Platform" while Bitbucket hosts and maintains their code repositories.

Figure C.1



It is important to note that when defining the scope of a system you as a lead implementor or consultant will look to see what “pieces of the puzzle” the system is made of. This will have a profound impact on the types of controls that you help design and implement for an organization.

Once you have a solid understanding of the system scope and the pieces of the puzzle, it's best to get confirmation from the organization's management team that all sub-level service organizations have been identified and are listed as in scope for the audit. It is also important to verify with management on whether these sub services would be included in the attestation report or will a carve-out method be used. Should it be the latter, then it should be clearly specified in section 1 of the report that all controls relating to the sub-service organization will be excluded.

The next steps in the audit scoping process would be to sit down and map out what controls types if any sub-level organizations would fall under. An example of this would be controls for availability. Most of the time when evaluating cloud services, controls that deal with availability will fall under the cloud hosting providers, such as Amazon AWS, Google Cloud, and Microsoft Azure. However, it will be the organizations' responsibility to ensure that these configurations and processes are put into place.

2.2 Creation of the System Description

What is the system description?

The system description is a document that describes the business environment in which the controls are designed and implemented. The description documents the people, processes, technologies, and accompanying controls for the organization. Think of this similar to a network architecture diagram, but with no diagrams and a lot of reading regarding the organizations' structure, processes, and controls. The

system description is intended to provide users with information about the system, particularly system controls intended to meet the criteria: security, availability, processing integrity, confidentiality, and privacy.

System description

The system description encompasses the following: infrastructure, applications, services, and people that make up the platform. Including the sub-level organizations that were identified previously.

Section III

Within the overall report produced by the auditors, they will oftentimes refer to what is known as section three of the report. This is essentially the system description that has been written by the organization and the defined scope the auditor(s) have audited against.

The section III portion of the SOC 2 report should be written by the organizations' management team with the lead implementer or consultant ensuring that it gets completed by the specified project date. Each department within the organization will most likely have a small subsection within the report. This would include but is not limited to; Human Resources, Information Security, Engineering and Development Teams, Operations, and Support. If you would like assistance with writing this section. Scytale has examples readily available for you to use.

Management's Approval

Depending on how the project has been scoped and the personnel involved. Once the Section III report or "System Description" has been created. It will be the responsibility of the consultant or lead implementer to have the management team review and approve the Section III outline. The system description can start to be worked on once a defined scope has been identified and set with the auditing team.

2.3 Types of Controls

As a lead Implementer when designing controls you first must understand what the control is trying to accomplish. You then have to determine what type of control is being put into place based upon the requirements from the SOC 2 Control. First, let's take a look at the three different types of controls.

Internal Auditing Controls

1. Detective
2. Preventative
3. Corrective

Detective Control - Controls that alert employees to an action. ie, Log Monitoring with Alerts, Data leak Prevention, Intrusion Detection System.

Preventative Control - Controls used to help prevent certain events from occurring. ie, Example - A signature is required before an employee spends over 2,000.00 dollars on a service or equipment.

Corrective Control - Control that takes corrective action based upon an event that occurred. For Example, the DevOps team developed a script to spin up in a new region if their current region goes down.

Compensating control

A compensating control is when a process or technology is deficient and would require enormous changes, or it would be very costly for the organization to remediate.

Oftentimes compensating controls are used more to assist information systems and IT processes, rather than business processes.

It's important to understand what controls are, and the different types that can be implemented.

Oftentimes technologies such as anti-malware will encompass all three control types, especially with newer systems such as Carbon Black and CrowdStrike that have a machine learning backend.

2.4 Gap Analysis

The gap analysis is a forward-looking review of the organization's controls and processes, that seeks to identify where there are shortcomings or subpar implementations that could result in security flaws, regulatory non-compliance or simply non-adherence to business and control environment best practices.

The gap analysis process is a forward-looking exercise. The current implementation of the process is examined, identifying any areas of concerns, and then a corrective action plan is drafted up, reviewed, agreed upon, and approved in order to provide guidance for how to remediate the identified gaps.

It is important to note that when performing a gap analysis for SOC 2, the organization should set out to

identify any gaps based on the relevant TSC for the scoping criteria relevant to the audit in particular. In order to successfully achieve this, the lead implementer should identify all controls and processes relevant to the organization (based on the TSC scope relevant to the audit) and then perform a line-by-line review of this to identify any relevant gaps.

Successfully performing the gap analysis process will set up the organization for SOC 2 success.

2.5 Identifying Gaps and Remediation

As mentioned, the gap analysis is a forward-looking, ongoing process. It should identify all relevant controls to the organization for the audit, evaluate the current operational processes and controls, identify where deficiencies exist, and provide clear, realistic guidance for resolving all focus areas.

The lead implementer should include all relevant parties for the gap analysis process in order to have an accurate understanding of the organizational controls and processes. The process should include inquiry, walkthroughs, etc, in order to have a precise understanding of the necessary controls and processes.

It is also important that all relevant parties are involved in order to establish accountability for the implementation in order to resolve these gaps.

Gap remediation should be prioritized according to the impact of the gap on the organization and its security in particular, as well as based on the benefit to the organization (by resolving this deficiency).

Time lines need to be established in order to maintain appropriate resolution of gaps as well as to provide feedback to any stakeholders regarding the improvement and forward-looking plans for the organization.

2.6 Creation and Mapping of Controls

You as a lead implementer or consultant will be responsible for leading the organization through a successful audit. As part of that criteria, sometimes you will need to assist organizations on mapping out controls that are currently in place to a point of focus that is mapped to a common criteria.

Have it be a business process, technical control, IT General Control or one of the three types of internal auditing controls we discussed previously. Let's first review the types of internal auditing controls along with an additional control type we discussed. They are the following:

Internal Auditing Controls

1. Detective Control

2. Preventative Control
3. Corrective Control
4. Compensating Control

After the scoping period which should have already occurred, you will have a better understanding of what the organization is using for technology, their processes, and the people that make up those processes.

It is now your duty to start designing controls based upon the Gap Analysis / Risk Assessment that was previously performed. To do this, you will take the Gaps that should be aligned with the Common Criteria and review the Points of focus associated with each component. This will provide you with an understanding of what the intended control you develop should accomplish.

2.7 Choosing the Auditing Firm-

What to look for

It's important for organizations when looking for an auditor that, they pick a firm with a proven track record of successful attestations. Often times its best to interview at least three different auditing firms.

Size Matters

Depending on the size of your organization it's best to start your search locally. Many times there is a local auditing firm that can provide the same if not better results than large firms that have many clients.

Personality types

You as a lead implementer or consultant for the organization will be working hand in hand with the auditing team. During the selection phase it's important to get to know their personalities. Ask yourself, can I envision myself working with this auditor in a continuous audit engagement?

Previous attestations and recommendations

Prior to selection, it's always nice to review your auditors' work from previous engagements. Ask them about controls they have found not suitably designed. For example, you could ask the auditor(s) the following questions.

1. How did you report on a control that you found not suitably designed and not operating effectively.
2. Did you assist the client with recommendations regarding how to fix the control?
3. What is the most common occurrence you see during the audit engagement that clients fail to understand?
4. Ask the potential auditor if they can provide a list of contacts so you can make a reference check.

5. Ask them about their sampling methodology to ensure it is in line with best practise.
6. Ask the relevant audit manager, how many SOC 2 attestation he/she has performed.

Communication Style

Communication style is important. Everyone communicates differently and when running point one a SOC 2 project for an organization. It's imperative that the communication barrier is broken down. You as a lead implementer for the organization will need to communicate with the organization as well as the auditors. You will need to translate the requirements to the business and then help communicate those findings back to the auditors. Ensuring to do it from their perspective.

3. Framework Subject Matters

The 9 trust services criteria (TSC) make up the framework which SOC 2 compliance is measured against. There are additional 4 other TSC's that can be included in the SOC 2 assessment, but is at the discretion of management and the lead implementer if they will be included in the attestation. The TSC presented below have been aligned to the 17 COSO principles, which are listed as common criteria.

In addition to the 17 COSO principles, the TSC include additional criteria supplementing COSO principle 12: The entity deploys control activities through policies that establish what is expected and procedures that put policies into action (supplemental criteria). These additional supplemental common criteria are reflected in the TSC "Logical and physical access controls" up until Risk mitigation the last TSC. Each common criteria have a couple of points of focus to guide management and the lead implementer on what controls will satisfy the common criteria. In essence, each point of focus represents important characteristics of the common criteria.

[Framework Subject Matters](#)

3.1 Control Environment

The control environment TSC have the following common criteria in place:

TSC ref #	Common Criteria
CC1.1	COSO Principle 1: The entity demonstrates a commitment to integrity and ethical values.
CC1.2	COSO Principle 2: The board of directors demonstrates independence from management and exercises oversight of the development and performance of internal control.
CC1.3	COSO Principle 3: Management establishes, with board oversight, structures, reporting lines, and appropriate authorities and responsibilities in the pursuit of objectives.
CC1.4	COSO Principle 4: The entity demonstrates a commitment to attract, develop, and retain competent individuals in alignment with objectives.
CC1.5	COSO Principle 5: The entity holds individuals accountable for their internal control responsibilities in the pursuit of objectives.

A control environment refers to a service organization's compliance culture and includes everything from organizational structure (and its different departments) to ethical values. This compliance culture, organization structure and ethical values needs to filter down from the top. Below are examples of possible control areas that should be mapped to the common criteria table above. Also keep in mind that the points of focus should also be used as guidance:

- A process on how ethical values are communicated to the employees and what training is done in this regard.
- HR onboarding process of new employees, which includes policies and procedures, screening processes and training programs.
- An organizational chart should be developed.
- Board and management meetings should be taking place and minutes should be kept.
- Policies and procedures for various business processes should be implemented e.g. Ethics policy, Security policy, HR policy, IT Policy, Leave policy, Bonus policy, KPC policy etc.

If the service organization has a well-functioning HR department, then compliance with the common criteria related to the Control Environment should be easy. In most SOC 2 audits, there are rarely any pitfalls if any in this TSC.

3.2 Communication and Information

The communication and information TSC have the following common criteria in place:

TSC ref #	Common Criteria
CC2.1	COSO Principle 13: The entity obtains or generates and uses relevant, quality information to support the functioning of internal control.
CC2.2	COSO Principle 14: The entity internally communicates information, including objectives and responsibilities for internal control, necessary to support the functioning of internal control.
CC2.3	COSO Principle 15: The entity communicates with external parties regarding matters affecting the functioning of internal control.

Quality information and effective communication within a service organization can impact meeting internal control objectives. When the service auditor needs to gain an understanding of the service organization, the first place that they will turn to is the service organizations documentation. While documenting is a tedious job (hopefully digitally), it is a way to bring the service auditor up to speed quickly when they have no other contextual understanding of the service organization or the system. Keep in mind from an auditor's eyes, if it isn't documented, then it didn't happen (or doesn't exist). In

terms of communication, this includes communication expectations between the Board of Directors, management, and employees, and between the company and external parties. This will also include security awareness training among employees of the service organization.

Below are examples of possible control areas that should be mapped to the common criteria table above. Also keep in mind that the points of focus should also be used as guidance:

- Policies and procedure for various business processes should be implemented e.g. Ethics policy, Security policy, HR policy, IT Policy, Leave policy, Bonus policy, KPC policy etc.
- A detailed description of the product architecture and system boundaries is documented and available internally to the company's employees.
- A Security Incident Response Policy is developed in order to respond to security incidents and personal data breaches in accordance with applicable regulations.
- Website that provides access for customers or other relevant stakeholders.
- Service interruptions communication channels are in place between the service organization and the customers.
- A support team is available at the service organization. Customers can contact the support team through support email, log a ticket or directly call them.
- A monitoring tool is deployed 24/7 to detect anomalies and service disruption.

While it is difficult to cover every specific common criteria requirement related to communication and information, this is a great starting point. If communication between the various internal and external entities of the business are clear, maintained and documented, this section should be an easy pass. Most issues we see here is a lack of maintaining evidence of these control activities, not the lack of control activities themselves.

3.3 Risk Assessment

The risk assessment TSC have the following common criteria in place:

TSC ref #	Common Criteria
CC3.1	COSO Principle 6: The entity specifies objectives with sufficient clarity to enable the identification and assessment of risks relating to objectives.
CC3.2	COSO Principle 7: The entity identifies risks to the achievement of its objectives across the entity and analyzes risks as a basis for determining how the risks should be managed.

CC3.3	COSO Principle 8: The entity considers the potential for fraud in assessing risks to the achievement of objectives.
CC3.4	COSO Principle 9: The entity identifies and assesses changes that could significantly impact the system of internal control.

When the service auditor looks at this TSC, the service organization needs to think about performing risk analysis that includes multiple tasks such as identifying assets, identifying the threats and vulnerabilities related to those assets, determining the likelihood and impact of those risks being realized, mitigating those risks, and dealing with any other issues that occur along the way.

Below are examples of possible control areas that should be mapped to the common criteria table above. Also keep in mind that the points of focus should also be used as guidance:

- A risk assessment register that indicates all the risks identified in the service organization, which includes the rating of these risks as well as the threats and vulnerabilities identified.
- A risk assessment policy reviewed annually and signed off.
- Regular risk assessment meetings should be held and the minutes of these meetings should be safeguarded.
- Vulnerability assessments are performed on the IT environment to identify any IT vulnerabilities.

From what we have read above, it is clear that this section of SOC 2 revolves around the risk assessment process. This includes identifying risks, mitigating and relevant risks, and implementing controls to minimize or eliminate those risks. The service organization should have a clear and formal process in place with regards to the risk assessment process. Key documentation will include the risk register/matrix.

3.4 Monitoring Activities

The monitoring activities TSC have the following common criteria in place:

TSC ref #	Common Criteria
-----------	-----------------

CC4.1	COSO Principle 16: The entity selects, develops, and performs ongoing and/or separate evaluations to ascertain whether the components of internal control are present and functioning.
CC4.2	COSO Principle 17: The entity evaluates and communicates internal control deficiencies in a timely manner to those parties responsible for taking corrective action, including senior management and the board of directors, as appropriate.

Because every organization is different when it comes to monitoring activities, a service auditor will seek to understand what the organization does and how they do it during a SOC 2 audit. Considering this, in order for an organization to demonstrate that they comply with TSC, they'll need to show that they are conducting evaluations of internal control.

Below are examples of possible control areas that should be mapped to the common criteria table above. Also keep in mind that the points of focus should also be used as guidance:

- An internal audit function should address the common criteria for this TSC. The internal audit plan will include ongoing evaluations of controls that communicate deficiencies, both internally and externally, when appropriate.
- Should an internal audit function not be available, then board and management meetings should be sufficient to cover the elements of internal control.
- The Management team should be meeting on a regular basis, in order to evaluate risks and threats and discuss any internal control deficiencies.

Essentially, having effective evaluations of internal control allows organizations to ensure that their internal controls are present and functioning, and if they aren't, the evaluations of internal control will give insight into the vulnerabilities that need to be remediated. As with the communication and information TSC, the lack of maintaining evidence of monitoring internal control can lead to a pitfall.

3.5 Control Activities

The control activities TSC have the following common criteria in place:

TSC ref #	Common Criteria
CC5.1	COSO Principle 10: The entity selects and develops control activities that contribute to the mitigation of risks to the achievement of objectives to acceptable levels.
CC5.2	COSO Principle 11: The entity also selects and develops general control activities over technology to support the achievement of objectives.

CC5.3	COSO Principle 12: The entity deploys control activities through policies that establish what is expected and in procedures that put policies into action.
-------	--

When the service auditor assesses an organization's compliance with this TSC during a SOC 2 audit, they will want to see that the organization has implemented internal controls that assist them in accomplishing their business objectives. This TSC can be a bit ambiguous and it is intended to be broad in order to allow organizations to implement the internal controls that work best for their organization and the goals they need to meet.

Below are examples of possible control areas that should be mapped to the common criteria table above. Also keep in mind that the points of focus should also be used as guidance:

- Controls relating to the risk assessment TSC, are found to be the best fit for this TSC.
- Board and management meetings also serve as a type of oversight control, ensuring internal control is operating effectively.
- The service organization separates duties of individuals by granting users access based on job responsibilities and least privilege and limiting access to only authorized users.
- Sensitive permissions (admin/super user access) granted to users should be reviewed by senior personnel (CIO for example).

The control activity TSC is all about management and the lead implementer choosing the right internal controls for the service organization, implementing internal controls, and making sure the variety of controls chosen is the right mix so that risk can be reduced altogether.

Let's use physical security as an example. If a service organization needs to implement internal controls to mitigate the risk of an unauthorized person entering sensitive areas of an office building, what would those look like?

An organization wouldn't use one internal control to mitigate this risk. Instead, a mix of control activity types would be necessary. This might include a locked front door, a receptionist or security guard, video cameras, access cards, and other individuals throughout the building who would be able to notify the proper personnel if an unauthorized person was on the property. By choosing this variety of controls, an unauthorized person would be far less likely to access a sensitive area than if only one of those internal controls was in place.

3.6 Logical and Physical Access Controls

The logical and physical access controls TSC have the following common criteria in place:

TSC ref #	Common Criteria
-----------	-----------------

CC6.1	The entity implements logical access security software, infrastructure, and architectures over protected information assets to protect them from security events to meet the entity's objectives.
CC6.2	Prior to issuing system credentials and granting system access, the entity registers and authorizes new internal and external users whose access is administered by the entity. For those users whose access is administered by the entity, user system credentials are removed when user access is no longer authorized.
CC6.3	The entity authorizes, modifies, or removes access to data, software, functions, and other protected information assets based on roles, responsibilities, or the system design and changes, giving consideration to the concepts of least privilege and segregation of duties, to meet the entity's objectives.
CC6.4	The entity restricts physical access to facilities and protected information assets (for example, data center facilities, back-up media storage, and other sensitive locations) to authorized personnel to meet the entity's objectives.
CC6.5	The entity discontinues logical and physical protections over physical assets only after the ability to read or recover data and software from those assets has been diminished and is no longer required to meet the entity's objectives.
CC6.6	The entity implements logical access security measures to protect against threats from sources outside its system boundaries.
CC6.7	The entity restricts the transmission, movement, and removal of information to authorized internal and external users and processes, and protects it during transmission, movement, or removal to meet the entity's objectives.
CC6.8	The entity implements controls to prevent or detect and act upon the introduction of unauthorized or malicious software to meet the entity's objectives.

This TSC encompasses a variety of controls that relates to access control in the control environment. These controls include safeguards to monitor and restrict access to sensitive data and any devices or networks on which it is stored, transmitted, or processed. Service organizations need to demonstrate that they're taking physical and virtual measures to protect data privacy, integrity, and confidentiality. Because employees are the weakest link of every organization, the proper measures must be taken to mitigate the risks associated with human error prior to engaging in a SOC 2 audit. Furthermore, when service organizations assign roles and responsibilities to employees, they implement the concept of "least access necessary" i.e. bare minimum access is given in order for the user to fulfill their job duties. Similarly, assigning roles and responsibilities assists service organizations in ensuring that there is a segregation of duties so that there are no conflicts of interest within the organization.

While malicious hackers often attack digitally, service organizations must account for the risk that their physical environments could be compromised too. This means that implementing physical security controls in facilities or other locations that hold sensitive information needs to be a top priority for service organizations.

Below are examples of possible control areas that should be mapped to the common criteria table above. Also keep in mind that the points of focus should also be used as guidance:

- A password policy should be in place with parameters complying with best practice.
- Access to production should be restricted.
- A process should be in place that reviews and approves all user access.
- Terminated user accounts should be managed in a timely manner.
- User access reviews should be performed on all users on a regular basis.
- Physical access should be managed and restricted to authorized personnel only.
- End point management – Disk level encryption, passwords and screen lock.
- Firewall rules are configured to restrict access to the computing environment and enforce boundaries of computing clusters.
- Access to backups are restricted.

Ultimately, this TSC aims to ensure that service organizations meet their business objectives by protecting their sensitive assets from malicious internal and external threats – both digitally and by physical means. More often than not, this TSC produces the most deficiencies, especially on an operating effectiveness level i.e. samples here and there tend to fail. For example, 10 signed user access forms are requested and only 9 are sign off by the CIO, which produces a deficiency.

3.7 System Operations

The system operations TSC have the following common criteria in place:

TSC ref #	Common Criteria
CC7.1	To meet its objectives, the entity uses detection and monitoring procedures to identify (1) changes to configurations that result in the introduction of new vulnerabilities, and (2) susceptibilities to newly discovered vulnerabilities.
CC7.2	The entity monitors system components and the operation of those components for anomalies that are indicative of malicious acts, natural disasters, and errors affecting the

	entity's ability to meet its objectives; anomalies are analyzed to determine whether they represent security events.
CC7.3	The entity evaluates security events to determine whether they could or have resulted in a failure of the entity to meet its objectives (security incidents) and, if so, takes actions to prevent or address such failures.
CC7.4	The entity responds to identified security incidents by executing a defined incident response program to understand, contain, remediate, and communicate security incidents, as appropriate.
CC7.5	The entity identifies, develops, and implements activities to recover from identified security incidents.

During a SOC 2 audit, an auditor will assess that an organization meets the requirements of this TSC by looking for the following:

- The entity uses defined configuration standards.
- The entity monitors infrastructure and software.
- The entity implements change-detection mechanisms.
- The entity detects unknown or unauthorized components.
- The entity conducts vulnerability scans.

Below are examples of possible control areas that should be mapped to the common criteria table above. Also keep in mind that the points of focus should also be used as guidance:

- Effective firewall configurations and hardening standards should be implemented. Firewall configurations play a critical role in protecting an organization's assets and hardening standards increase the level of security of an organization's systems.
- Vulnerability scans are performed on the production environment using a dedicated tool in order to identify issues.
- Monitoring tool is deployed 24/7 to detect anomalies and service disruption.
- Audit logs are continuously monitored for events related to security, availability, and confidentiality threats. Alerts are generated for further investigation.
- A Security Incident Response Policy should be in place, in order to respond to security incidents and personal data breaches in accordance with applicable regulations.

These are some examples of ways that the service Organization would detect and monitor changes and new vulnerabilities. Management and the lead implementer needs to think how they would do that in their environment, and specifically think about what their standard is to begin with. What is their goal in how these things should be configured? How tight do they want it to be?

Again, management and the lead implementer should think of things in terms of “default-deny policy”. They should start with nothing installed and only specifically allow the things that are necessary for the system to do what it is they expect it to do, and the software, ports, and services that are necessary for the service Organization. An effectively configured firewall, a monitoring tool and vulnerability scans should allow this TSC to pass.

3.8 Change Management

The change management TSC have the following common criteria in place:

TSC ref #	Common Criteria
CC8.1	The entity authorizes, designs, develops or acquires, configures, documents, tests, approves, and implements changes to infrastructure, data, software, and procedures to meet its objectives.

It's especially important that service organizations can demonstrate to the service auditors that they have an effective change management system in place. Change management systems provide organizations with policies and procedures for making updates to their IT infrastructure, which in turn helps mitigate the potential for overlooking any new vulnerabilities or risks created while changes are taking place. Service organizations have used a variety of different change management systems, from simple forms to elaborate ticketing systems. Whichever way an organization chooses to implement their change management system, though, they should end up with a database that allows them to review all of the changes that have been made at their organization, who authorized them, who tested them and who implemented them.

Below are examples of possible control areas that should be mapped to the common criteria table above. Also keep in mind that the points of focus should also be used as guidance:

- A change management policy should be in place that details the whole change management process.
- All changes need to follow a change management process where changes are tested, reviewed, and approved.
- Segregation of duties - Users who have access to the development environment, should not have access to implement changes in the production environment.

- Environments should be segregated between, dev, test/QA, and prod.

The best way to pass the TSC is to have a change management policy and procedure in place according to best practice and ensuring whatever is in that document is implemented in the service Organization. One of the most common deficiency is developers having access to production. Ensure that the service Organization has a tool in place to manage, track, review, and approve all changes. That way evidence will be maintained and auditors will be able to audit this TSC with ease.

3.9 Risk Mitigation

The risk mitigation TSC have the following common criteria in place:

TSC ref #	Common Criteria
CC9.1	The entity identifies, selects, and develops risk mitigation activities for risks arising from potential business disruptions.
CC9.2	The entity assesses and manages risks associated with vendors and business partners.

It's inevitable that the service Organization will encounter some type of security incident. Whether it's a big or small incident, organizations who mitigate risks that lead to business disruptions will be better prepared.

For service organizations committed to delivering secure services, they'll need to demonstrate to the service auditor during a SOC 2 audit that they mitigate risks that lead to business disruptions.

Below are examples of possible control areas that should be mapped to the common criteria table above. Also keep in mind that the points of focus should also be used as guidance:

- Implement a business continuity plan and ensure that it is tested at least annually. The testing evidence needs to be supplied to the auditors.
- Purchase business insurance.
- Risk assessment meetings should take place at least annually and the meeting minutes should be kept as evidence for the auditors.

For this TSC to pass, a well-documented business continuity plan must be in place, along with evidence that it was tested on an annual basis. Controls documented in the risk assessment TSC can also be used in this TSC, however it is key the service Organization demonstrates to the auditor that all risks in the business are mitigated in some way, especially the risk that the Organization cannot continue to do business because of power, accidents, natural disasters, etc.

3.10 Additional Criteria for Availability

The additional criteria for availability TSC have the following common criteria in place:

TSC ref #	Common Criteria
A1.1	The entity maintains, monitors, and evaluates current processing capacity and use of system components (infrastructure, data, and software) to manage capacity demand and to enable the implementation of additional capacity to help meet its objectives.
A1.2	The entity authorizes, designs, develops or acquires, implements, operates, approves, maintains, and monitors environmental protections, software, data back-up processes, and recovery infrastructure to meet its objectives.
A1.3	The entity tests recovery plan procedures supporting system recovery to meet its objectives.

The easiest way to explain this TSC, is to look at the service Organizations system and ask the question: Is the system available for operation at all times or as agreed upon with their customers? For organizations that need to include availability in their SOC 2 audits, such as cloud service providers or storage facilities, preparing for current and future availability needs is a necessity. For example, if a data center doesn't maintain, monitor, or evaluate the current processing capacity of their system, they might have an outage that would make their systems unavailable, which would greatly impact their customers' business continuity.

Below are examples of possible control areas that should be mapped to the common criteria table above. Also keep in mind that the points of focus should also be used as guidance:

- Service interruptions are communicated to clients based on the escalation procedures and a Service Level Agreement (SLA).
- The company uses a suite of monitoring tools to monitor its service e.g. data centre services.
- Alerts are sent to relevant stakeholders by an internal communication tool, based on predefined rules. The notifications are reviewed and processed according to their level of urgency.
- Back up policy and procedure is in place and databases and application servers are backed up as per policy / best practice.
- System components are replicated across multiple Availability Zones and backups are maintained.
- Disaster recovery plan prepared and implemented. The plan should also be tested annually.

More often than not, the auditor will be concerned about two things: (1) Are service interruptions managed as per the SLA and (2) Is there a disaster recovery plan in place AND is it tested.

Make sure those two things are on point and this TSC will pass. Backups are also important, but normally are not a concern and most companies have backup procedures in place.

3.10 Additional Criteria for Confidentiality

The additional criteria for confidentiality TSC have the following common criteria in place:

TSC ref #	Common Criteria
C1.1	The entity identifies and maintains confidential information to meet the entity's objectives related to confidentiality.
C1.2	The entity disposes of confidential information to meet the entity's objectives related to confidentiality.

The term "Confidential information" and its meaning can vary between organizations or location throughout the world and potentially cover a wide range of information security practices. If the service organization has contracts in place with its clients related to the protection of data, then the confidentiality TSC should be considered.

Unlike personal information (covered by the Privacy TSC below), confidential information is not so easily defined. Any personal or non-personal information or data can be designated as confidential, and once it is, it needs to be protected appropriately, or as agreed upon with clients. Interpretations of this type of information often vary significantly from one client or company to another.

Below are examples of possible control areas that should be mapped to the common criteria table above. Also keep in mind that the points of focus should also be used as guidance:

- Identification of confidential information - Procedures are in place to identify and label confidential information when it is received or created and to determine the period over which the confidential information is to be retained.
- Safeguarding of confidential information from destruction - Procedures are in place to protect confidential information from deletion or destruction during the specified retention period of the information.
- Destruction of confidential information- Procedures are in place to identify confidential information requiring destruction when the end of the retention period is reached.

While the confidentiality TSC is not required in a SOC 2 examination, it is an important TSC for service organizations that need to demonstrate how they are keeping client data confidential.

3.11 Additional Criteria for Processing Integrity

The additional criteria for processing integrity TSC have the following common criteria in place:

TSC ref #	Common Criteria
PI1.1	The entity obtains or generates, uses, and communicates relevant, quality information regarding the objectives related to processing, including definitions of data processed and product and service specifications, to support the use of products and services.
PI1.2	The entity implements policies and procedures over system inputs, including controls over completeness and accuracy, to result in products, services, and reporting to meet the entity's objectives.
PI1.3	The entity implements policies and procedures over system processing to result in products, services, and reporting to meet the entity's objectives.
PI1.4	The entity implements policies and procedures to make available or deliver output completely, accurately, and timely in accordance with specifications to meet the entity's objectives.
PI1.5	The entity implements policies and procedures to store inputs, items in processing, and outputs completely, accurately, and timely in accordance with system specifications to meet the entity's objectives.

The processing integrity criteria is designed to ensure that there are no errors in processing and if there are, these errors are then detected in a timely manner and corrected accordingly.

Additionally, the processing integrity criteria covers inputs and outputs to and from the system, and that they are accurate throughout the processing of the data. Lastly, this TSC covers data and how it is stored and maintained.

Below are examples of possible control areas that should be mapped to the common criteria table above. Also keep in mind that the points of focus should also be used as guidance:

- Input validation controls on key fields are implemented.
- System edits require mandatory fields to be complete before record entry is accepted.
- Electronic files received contain batch control totals. During the load processing, data captured is reconciled to batch totals automatically by the application.
- Inputs are coded with identification numbers, registration numbers, registration information, or time stamps to enable them to be traced from initial input to output and final disposition and from output to source inputs.

- Data is reconciled on a monthly basis by rolling forward prior period balances with monthly activity and comparing results to the stored data balances.
- The service auditor will walk through the services provided to the service Organization's clients and identify control points in the process. Management and the lead implementer need to ensure that those controls are adequately designed, implemented and operating effectively for the period of intended review.

The processing integrity TSC is not required in SOC 2 reports, but if the service Organization is completing processing or transactions on behalf of their clients, they may want to include it. Chances are their clients will ask for processing integrity to be included in the SOC 2 report.

3.12 Additional Criteria for Privacy

The additional criteria for privacy TSC have the following common criteria in place:

TSC ref #	Common Criteria
P1.0	Privacy Criteria Related to Notice and Communication of Objectives Related to Privacy
P1.1	The entity provides notice to data subjects about its privacy practices to meet the entity's objectives related to privacy. The notice is updated and communicated to data subjects in a timely manner for changes to the entity's privacy practices, including changes in the use of personal information, to meet the entity's objectives related to privacy.
P2.0	Privacy Criteria Related to Choice and Consent
P2.1	The entity communicates choices available regarding the collection, use, retention, disclosure, and disposal of personal information to the data subjects and the consequences, if any, of each choice. Explicit consent for the collection, use, retention, disclosure, and disposal of personal information is obtained from data subjects or other authorized persons, if required. Such consent is obtained only for the intended purpose of the information to meet the entity's objectives related to privacy. The entity's basis for determining implicit consent for the collection, use, retention, disclosure, and disposal of personal information is documented.
P3.0	Privacy Criteria Related to Collection.

P3.1	Personal information is collected consistent with the entity's objectives related to privacy.
P3.2	For information requiring explicit consent, the entity communicates the need for such consent, as well as the consequences of a failure to provide consent for the request for personal information, and obtains the consent prior to the collection of the information to meet the entity's objectives related to privacy.
P4.0	Privacy Criteria Related to Use, Retention, and Disposal.
P4.1	The entity limits the use of personal information to the purposes identified in the entity's objectives related to privacy.
P4.2	The entity retains personal information consistent with the entity's objectives related to privacy.
P4.3	The entity securely disposes of personal information to meet the entity's objectives related to privacy.
P5.0	Privacy Criteria Related to Access.
P5.1	The entity grants identified and authenticated data subjects the ability to access their stored personal information for review and, upon request, provides physical or electronic copies of that information to data subjects to meet the entity's objectives related to privacy. If access is denied, data subjects are informed of the denial and reason for such denial, as required, to meet the entity's objectives related to privacy.
P5.2	The entity corrects, amends, or appends personal information based on information provided by data subjects and communicates such information to third parties, as committed or required, to meet the entity's objectives related to privacy. If a request for correction is denied, data subjects are informed of the denial and reason for such denial to meet the entity's objectives related to privacy.
P6.0	Privacy Criteria Related to Disclosure and Notification.
P6.1	The entity discloses personal information to third parties with the explicit consent of data subjects, and such consent is obtained prior to disclosure to meet the entity's objectives related to privacy.
P6.2	The entity creates and retains a complete, accurate, and timely record of authorized disclosures of personal information to meet the entity's objectives related to privacy.

P6.3	The entity creates and retains a complete, accurate, and timely record of detected or reported unauthorized disclosures (including breaches) of personal information to meet the entity's objectives related to privacy.
P6.4	The entity obtains privacy commitments from vendors and other third parties who have access to personal information to meet the entity's objectives related to privacy. The entity assesses those parties' compliance on a periodic and as-needed basis and takes corrective action, if necessary.
P6.5	The entity obtains commitments from vendors and other third parties with access to personal information to notify the entity in the event of actual or suspected unauthorized disclosures of personal information. Such notifications are reported to appropriate personnel and acted on in accordance with established incident response procedures to meet the entity's objectives related to privacy.
P6.6	The entity provides notification of breaches and incidents to affected data subjects, regulators, and others to meet the entity's objectives related to privacy.
P6.7	The entity provides data subjects with an accounting of the personal information held and disclosure of the data subjects' personal information, upon the data subjects' request, to meet the entity's objectives related to privacy.
P7.0	Privacy Criteria Related to Quality.
P7.1	The entity collects and maintains accurate, up-to-date, complete, and relevant personal information to meet the entity's objectives related to privacy.
P8.0	Privacy Criteria Related to Monitoring and Enforcement
P8.1	The entity implements a process for receiving, addressing, resolving, and communicating the resolution of inquiries, complaints, and disputes from data subjects and others and periodically monitors compliance to meet the entity's objectives related to privacy. Corrections and other necessary actions related to identified deficiencies are made or taken in a timely manner.

When considering if the Privacy TSC should be included in a SOC 2 audit, the guidance states that the Privacy criteria "is not applicable for a service organization that does not directly collect personal information from data subjects." The service organization and the lead implementer must analyse the data collected on its customers and determine if it meets the criteria of personal information.

A strong privacy program which is performed in conjunction with the common criteria/Security Criteria, is the best way to ensure privacy of customer data. In essence, should the service Organization have sufficient controls in place that covers all the TSC from control environment to risk mitigation, then the privacy TSC common criteria should be covered.

Privacy is governed by various country privacy regulations and is reported in the news when cybersecurity breaches occur. As mentioned above, privacy cannot be achieved without the appropriate security controls implemented in the control environment. Management and the lead implementer should ensure that all the common criteria across the TSC is addressed, which means the privacy TSC common criteria will also be addressed.

4: Prepare For Implementation

4.1 Shared Responsibility Model

In all engagements for a SOC 2 attestation. There is a shared responsibility model that is in place between you as a lead implementer, the service auditor, and the organization. That shared responsibility model encompasses trust between all three parties.

Lead Implementer - You as the lead implementer will be responsible for the gap analysis assessment, designing and implementing controls, and act as a vital communication line back to the organization.

Service Auditor - The service auditors' duties will be to run point on the engagement from an audit perspective. They will ask for the samples, examine testing output against the controls.

Organizational Roles - The organizations' responsibility will be to listen and ensure that deadlines are being met to achieve a desirable and favorable attestation report. The organization will need to work in tandem with the lead implementer to ensure the following: roles are known, timelines are set, and the evidence is collected in a timely fashion.

4.2 Key Stakeholder Identification

Setting the tone

After the organization has selected an auditing firm for the engagement. It's important that as a lead implementer or consultant, you define "who" from the organization will be in charge to assist with the following responsibilities. This should include multiple people from different departments within the organization.

Responsibilities of Organization

Control Design	Policy Owners	Creation of System Description
Define Control Owners	Managed Services	Process & Procedures Owners
Evidence Collection	Identification of Sub Service Providers	Management Response Team

Stakeholder Identification is important because it will allow you the opportunity to not only meet the team you will be working with for the foreseeable future, but it also helps you establish a relationship with team members as SOC 2 has a rolling audit period.

Please note that the table above does not encompass everything needed for stakeholder identification. Every organization and platform is different, be sure to take the time to understand the organization, technology, and most importantly the people that make the magic happen.

4.3 Technical, Procedural, and Administrative Controls Implementation

Earlier in this course we discussed 3 different types of internal auditing controls. They were detective, preventative, and corrective controls. Now we're going to discuss technical, procedural, and administrative controls.

Technical Control - A control type that is covered under a technical system or device.

Examples - Anti-malware, System Incident Event Management System

Procedural Control - A process in which employees or software performs an action to achieve the desired result. *Examples* - User access review, Annual policy updates, Endpoint compliance reviews

Administrative Control - A guideline that a business or business unit publishes in order to comply with the compliance objectives, or the law.

Examples - New company policy, Code of conduct,

Each company will have different controls depending on company size, and technology used. However, the over-arching objectives for the controls are the same regardless of what technology is being used. You will find that companies will sometimes use a process to comply with technical controls. Whereas another company may have the control covered end to end with automation.

Control deficiencies and Implementation

Now that we have talked about the following control types and what they entail, your job as a consultant or lead implementer will be to assess after the gap analysis if any new controls need to be designed to ensure the organization is meeting its compliance requirements. This should be completed after the gap analysis.

4.4 Prioritization

Keeping the organization on track

While there are many steps when preparing an organization for a SOC 2 attestation. There is nothing more rewarding than keeping them on track. Listed below is a prioritization list, this list should be adapted to your project plan and the organizations' needs.

Prioritization list

1. Selecting an Auditor
2. Identification of Key Stakeholders
3. Performing a Gap Analysis

4. Selecting and Designing Controls
5. Control Implementation
6. Control Monitoring
7. Submission of Evidence

Your job will be to prioritize both the auditors' needs and the organizations' needs while maintaining an open line of communication to both parties. The list above is in chronological order as to what should be completed from a project planning perspective.

Prioritization of Controls

After you have identified gaps within the organization, you will need to sit down and have a detailed conversation with them. This will include discussing potential budgetary adjustments to ensure the organization is committed to achieving a satisfactory SOC 2 attestation.

You will need to layout and define the missing controls that need to be in place to achieve the desired Trust Services Criteria that was selected by the organization. At a minimum, they must comply with the common criteria. Where only one control is identified to address a common criteria, it might be worthwhile to design and implement another control. This will help prevent a common criteria from failing, by having a “back up” control in place.

5. Security Management Procedures

5.1 Policies and Procedures

Looking at the organization as a whole you need to look at the people, processes, and technology that encompass the organization. The policies are what guide the organization forward and the processes are what guide the employees within the organization to accomplish the desired procedures.

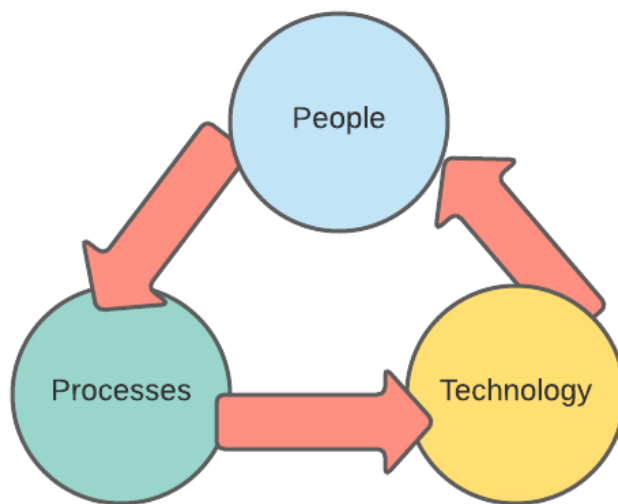
Most of the time the company will use technology to accomplish these goals. Thus you have People, Processes, and Technology at the heart of what the auditors will be measuring the controls against.

Policies > Processes > Procedures

As a lead implementer for your SOC 2 program you will need to set out and define what policies are needed for the organization. Some things to consider when designing and implementing a policy.

Considerations for policy implementation

1. Is the policy needed?
2. Will it impact the organization?
3. What is the desired outcome for the policy?



5.2 Passwords and MFA

While we are on this topic let's have a short discussion regarding three types of authentication factors that are offered to users by most of today's computing systems.

Authentication Factors

1. Passwords - Something that you know
2. Biometrics - Something you are
3. Token - Something you have

When looking at the controls that have been developed for an organization. It is important to remember that passwords must be in compliance with the password policy that has been defined for the organization. Also, several controls within the common criteria deal with Multi-factor Authentication. It will be your job to check to see those authentication systems in scope of the audit, encompass MFA.

Example Password Policy

1. Minimum of 8 Characters
2. Special Character Required
3. Uppercase Character Required
4. Lowercase Character Required

Examples of MFA use cases

1. A Hard Token (Employees Carry a Physical Token Providing a Random Number)
2. An email containing 6 - 8 digits for one-time use
3. An SMS message is sent to a phone number usually 6 - 8 digits

Additionally, the organizations using MFA, should have this defined in their password policy and it should list if there are any exceptions to this policy. For example, service accounts might need access to write data or move data based upon certain data jobs within the platform. Obviously, since it is a service account and the job is automated, the service account can not input a two-factor authentication code.

5.3 Risk Assessment

Every organization should be performing some type of Risk Assessment. Risk Assessments can vary in nature and degree. However, they should lay out risks from both a business and technical perspective. Oftentimes you'll encounter that organizations are not performing a risk assessment at all.

Business Risk Assessment

Business Risk Assessment should address the following.

1. ***Insider threats***
2. ***Business Continuity & Crisis***
3. ***Legal Risks*** "Data Privacy, Compliance with Federal, State, Country-Specific Laws"
4. ***Cyber Insurance*** "Vertical Specific"
5. ***Data Mapping*** - "Where is the data" Customer Data
6. ***Managed Services***
7. ***Sub Organization Processors***

It will be your job to help lead these discussions with the business and document the results. From these conversations, you will be able to layout risks from a business perspective that will help define what risks the organization is susceptible to. If you're a Scytale AI lead implementor, check with your manager for a defined template to use to assist you and your team during this exercise.

When looking at the technical risk assessment there are multiple different domains within that category. Depending on how in-depth you want to assess the organization. These types of risks assessments can vary. What should be included in a typical risk assessment is defined below.

Technical Risk Assessment

1. Assets Management
2. Identity Access Management
3. User Access Reviews
4. Third-Party Penetration Test
5. Vulnerability Scanning
6. Log Aggregation
7. Intrusion Detection & Prevention
8. Managed Services "Technical Consulting"
9. Code vulnerability scanning
10. Change management

The items for the technical risk assessment above will not be inclusive to all organizations however it is meant to be a guide. At a minimum, all organizations should be undergoing at least internal vulnerability scans of their infrastructure, code scanning prior to deployment to production, and a penetration test performed by a third party.

Secondly, log aggregation is meant to serve as a way to detect and respond to events before they become critical or worse, turn into a crisis for an organization. Log aggregation can often be expensive,

however, you as a lead implementer should assist in coming up with solutions that will fit the organization's budget and needs.

If you're a Scytale lead implementer, be sure to use the templates we have defined for guiding the organization through this process. After the risk assessments are completed, it will be your job to communicate the findings to the organization and then move on to the risk remediation phase.

Risk Assessment

After both the business and technical risk assessments have been conducted. You will need to then review the findings, then assign it a risk score based upon your own defined matrix and scoring model. It's best to look at the organization as a whole when determining risk.

Developing The Risk Matrix

The table below represents a snapshot of what the final report to an organization's management team should look like. It should address critical and high findings first and then medium findings. If it's a low finding it should be included in the overall report, however, redacted from the management or executive report unless otherwise stated by the management team.

Example - Risk Matrix

Severity	Identified Risk	Probability of Risk Occurring
Critical	"Risk 1"	23%
High	"Risk 2"	85%
Medium	"Risk 3"	15%
Low	"Risk 4"	27%

5.4 Risk Mitigation

Risk Assessment

After both the business and technical risk assessments have been conducted. You will need to then review the findings and assign a risk score based upon your own defined matrix. Next you will need to Mitigate that risk, or put in place a compensating control to limit risk exposure.

Control Types

Earlier in this course we discussed different control types. They were identified as the following

1. Preventative
2. Detective

3. Corrective

Now is the time to review your risk matrix and align each risk to a control type. If you have already performed this as part of your scoring model, then this is not needed. However, It's easier to have the mitigating control type listed alongside the risks.

Severity	Identified Risk	Probability of Risk Occurring	Mitigating Control Type
Critical	"Risk 1"	23%	Corrective
High	"Risk 2"	85%	Compensating
Medium	"Risk 3"	15%	Detective
Low	"Risk 4"	27%	Preventative, Detective

Formula for Determining Risk - High-Level Explanation

Drawing from this information you can now start to develop risk mitigations based upon the scoring model or risk matrix you have developed. During this time your main focus will be working with the organization to come up with controls to mitigate the risk.

Some of the control types you develop and implement to minimize risk could impact budget. It's important to understand this concept and ensure the organizations' management team is aware that if deficiencies exist they could cost money and resources to fix.

Risk Acceptance

During this time, if you have found that the organization is willing to tolerate or accept a certain level of risk. Please ensure that it is notated and explained to the audit team. As a lead implementer, it is not your job to force the organization to mitigate risk but for them to understand the risk level and for them to determine the level of acceptance. It's also important to ensure that the level of risk acceptance does not fail a common criteria which may lead to a qualified audit opinion.

5.5 User Access Review

User Access Reviews

One of the most important controls that any organization will undertake is performing user access reviews.

What are user access reviews?

Essentially it is reviewing the permissions of employees within the defined scope of the audit. Oftentimes, user access reviews will also ensure that employees that have been terminated actually have their accounts revoked.

How are user access reviews performed?

That is a great question and will vary from organization to organization. Each organization will be using different technology. However, they should have one thing in common: An identity access management platform. For very small organizations, this may not be true. However, for larger organizations, the user access reviews will make life easier if they have an identity access management platform.

User Access Review Steps

1. Pull the current list of employees from human resources
2. Pull the current list of all employees that are active inside of the Identity management platform.
"Ensure that each active employee id is also notated within the identity management platform, If this has not occurred, please have the organization do this on your behalf and ensure a process is put in place to enforce this going forward"
3. Cross-reference the two lists and reconcile
4. Notate your findings
5. Remediate any findings

Another detailed user access review would be to also pull the permission groups within the defined scope of the platform and associated infrastructure. This will include things like databases, servers, or computerless instances. From here, you would review job descriptions, job duties and notate any potential deviations.

Again, organization size is another factor in this type of review. Some people in the organization might wear multiple hats. That is perfectly fine, however, be sure to notate it as a finding.

5.6 Security Awareness Training

Trainings - We all take them

Found across many frameworks from CIS, NIST, PCI, SOC 2, and HighTrust. One thing they all have in common is for end-users in the organization to be trained on how to spot, prevent and report potential attacks against the organization.

More than just training

Security Awareness training also known as cyber awareness training is not just about checking a compliance checkbox, but also trying to give the end-users in the organization the tools necessary to be alert against things like phishing and malware.

After all, business email compromises are one of the easiest ways for hackers, and nation-states to steal data, gain access to a network, or worse deploy ransomware.

You as a lead implementer or consultant is to ensure that the organization is compliant with this requirement. If you're an implementer for Scytale, don't worry our platform encompasses this feature for organizations' end users.

This will be audited using automation. However, if not. You must ensure that the organization is performing end-user security awareness training at least on a yearly basis.

Audit Method

1. Pull list of all employees from human resources
2. Pull list of all employees that have successfully completed training
3. Reconcile list
4. Notate any findings or deviations

Topics that should be included in the security awareness training include basic cyber security principles, phishing examples, ransomware, and social engineering concepts that end-users could face.

5.7 Security Risk Vs Security Vulnerabilities

Quick Notes

In this section, we will look at security risks and security vulnerabilities. The difference between the two and how you should be measuring them differently. In an earlier section within this module, we talked about risk assessments both from a business and technical perspective.

On a similar note, security risks can encompass both business and technical risks. Whereas security vulnerabilities are mainly technical.

Let's review examples of a security risk both from a business and technical perspective.

Examples

1. A business does not have Cyber Liability Insurance, however, they process and store patient health information and have over 2.3 million records.
2. A business is not performing internal or external vulnerability scans of their infrastructure.

Let's review and talk about the examples above

1. From the first example, we have determined that a business is not carrying cyber liability insurance. Some businesses may think that because they have great technical and administrative controls in place this isn't needed. However, in today's advanced world where more lines of code are pumped out than ever before, more and more zero days will become prevalent; thus increasing the risk for the organization. Especially when relying on third parties.

2. A business is not performing internal or external vulnerability scans of its infrastructure. This is a security risk that can be easily mitigated by having the business perform internal and external scanning. the control may be technical in nature, but overall it is a security risk.

Security vulnerabilities

What is a security vulnerability? In essence, it's when a technical shortcoming has occurred within a system, code, or process and can be exploited for profit, personal gain, or data enrichment.

Examples of Security Vulnerabilities

1. The organization that did not have vulnerability scanning before now has a tool in place to perform scanning of internal and external resources. The tool produces a report detailing the vulnerabilities for several systems. Oftentimes these systems are running a certain application or service that is vulnerable, or the operating system itself is susceptible to attack. This would be known as a security vulnerability.
2. A business has just implemented new RFID badges to allow employees access to the building during normal working hours. However, the RFID badges that they have implemented are not encrypted. One day an attacker decides to implant a reader next to the actual door reader so that he can copy employee badge codes and provision himself a badge to gain access to the building. This is a vulnerability and not a security risk.

Let's review example number 2 under security vulnerabilities, and talk about why it is a vulnerability and not a security risk. Essentially the business did not use encrypted RFID badges. However, if they did use encrypted badges it would be a security risk. This is because it would take an attacker considerable time to break the encryption and provision himself a badge, whereas the badge numbers are in plaintext and the attacker can copy the badge and provide him/her self access.

5.8 Endpoint Management and Anti-Malware

In today's ever-growing remote workforce-enabled world, this is a control that should be taken seriously. You as a lead implementer will be responsible for ensuring that organizations have an employee endpoint solution in place. The endpoint management solution should have the following capabilities or minimum set of requirements.

Requirements for Endpoint Management Solution

1. Deploy software
2. Remote Wipe
3. Remote Lock
4. View Versions of Applications

Granted not all endpoint solutions have these features, and multiple agents "different solutions" may have to be deployed on endpoints to accomplish the list above. However, use it as a reference when designing and implementing controls for an organization.

You as a lead implementer will be responsible for assisting the organization with auditing and pulling this information together.

Audit Steps

1. Obtain a listing of all active employees from human resources
2. Populate listing of all endpoints from endpoint management solution
3. Reconcile lists and compare
4. Report deficiencies found
5. Notate Deviations
6. Ensure Remediation Occurs
7. Check that Anti Malware software is set to automatically download the latest configurations

Note - For very large organizations this is like a moving target, the success rate for this audit will rarely come back at 100 percent. Employees leave, employees get terminated, new employees are hired, and IT departments get behind. Especially when it comes to equipment returning, success criteria for this audit should be within the 95th percentile. However, if the organization is small, a larger percentile should be used.

Anti Malware

Also another point we are going to focus on here is anti-malware. Most organizations see this as an expense. However, more than ever with a remote workforce, this needs to be in place. Like we talked about earlier, the organization is a target, the bigger the target, the more likely organizations are to become breached.

Traditional Anti-malware

Traditional anti-malware systems still exist and will provide coverage for compliance. However please note, there are delays between when updates are provided for traditional anti-malware systems that are hash-based. Depending on the size of the organization and data involved this could be a security risk.

Next-Gen Anti-Malware Systems

Next-Gen Anti-Malware systems encompass both traditional and newer features, oftentimes these systems have hooks into the kernel of the operating system and look at things such as software signatures, process manipulation, and will have an AI or behavioral monitoring system used in the cloud, these systems are more advanced.

Audit Steps

1. Pull a listing of all machines from the endpoint management solution
2. Pull a listing of all machines that are active from the Anti-Malware platform
3. Reconcile the list and compare
4. Report deficiencies found
5. Notate Deviations
6. Ensure Remediation Occurs

5.9 Assets Mapping and Classification

If you have ever worked for a large enterprise, you know how daunting it can be to get up to speed on things. Things are oftentimes slower, there are more standard processes in place and oftentimes it's really boring. With that being the case, the larger the organization becomes, the more data it has. Big Business = Big Data.

To ensure that this information is not lost, it's important for organizations at the soonest possible stage to implement data classification and asset mapping. Not to mention, it can become a nightmare when things are unorganized. Let's first talk about data classification.

Data Classification

Data classification can be different for organizations, some organizations will deal with personally identifiable information, whereas others might have protected health information. Depending on the organization and the types of data they are working with, they will need to implement a data classification program. The data classification should be a set of procedures that contain multiple processes.

Example

Acme Corporation is standing up a new database that will handle a large volume of health-protected information. This information contains the patients' social security number, patient id, name, and health records. Once this database has been placed into production, it should be tagged within the asset management tool or architecture diagram that this database contains protected health information. Other ways organizations could also classify these types of systems is through an internal classification system that is pertinent to them.

Lead Implementer or Consultant Role

Your responsibility as a lead implementer will be to take the organization on a journey to find out where the data is located and implement a classification system. If one is already in place, be sure that that data classifications are readily available for your review.

Audit Steps

1. Select multiple assets that have not been defined in the data classification program
2. Define owner for each asset
3. Audit the asset to see if confidential data resides on the system, database, or flat storage.
4. Report deficiencies
5. Notate findings
6. Remediate if necessary

Asset Mapping

As we mentioned earlier, Big Data = Big Business. However, another important component is asset mapping and tracking. There are several reasons why this is important.

1. Having a detailed asset map allows you to visualize what assets are in existence in your production network.
2. It allows you from a network perspective to see potential data flows between systems. This is important if a security breach has occurred.

Lead Implementer Role

Your responsibility as a lead implementer will be to ensure that the organization has a detailed mapping of all assets that are in the production environment. This mapping could be a visual network architecture diagram, showing data flows across the organization.

Audit Steps

1. Ask the organization to produce an updated architecture diagram
2. Review the production network and notate the network subnets and data flows
 1. You will need to graphically layout yourself what the network looks like
 2. Notate the subnets, if any
3. Compare your diagram and findings against what was produced by the organization
4. Report Findings
5. Report Deficiencies
6. Ask Questions (Ask More Questions)
7. Notate Findings
8. Remediate if necessary

5.10 Human Resources

Recruitment

The human resources department in regards to SOC 2 audit has an instrumental part in helping the organization obtain an unqualified opinion, and it all starts with its most basic practice “recruiting”.

The human resources department should have a process in place to recruit top talent. In regards to recruiting top talent. The organization should be collecting and receiving recruiting documents so that they can be easily stored and accessed. Most commonly this is performed by an HR solution provider such as Greenboard, BambooHR, or for larger organizations PeopleSoft or ADP solutions.

Although recruiting practices remain largely the same across organizations, a lot of organizations still lack the process of completing a reference and background check for newly hired employees. This is because the organization doesn’t want to spend the time, money, and resources on a potential candidate. However, this is an administrative control that should be implemented early on in a company, since this is a control output that will be expected to be produced for a SOC 2 audit.

Example recruiting process

1. Candidate submits application
2. Review of candidates' qualifications
3. Interview setup
4. Interview scheduled with candidate
5. Home assignment for the candidate to review and complete if applicable
6. Evaluation of assignment
7. Second round interview if necessary
8. Selection process
9. Start date set and onboarding

What a lot of organizations lack is simple proper planning; An organization can miss out on a great candidate if they fail to notify the candidate in a timely manner and keep up with communication in regards to where the candidate is during the interview process. This process will need to be defined and laid out for review.

As of this writing, businesses are experiencing something known as the great resignation. This has never occurred before throughout history and, going forward employers should work towards exciting and retaining employees. Once an employee leaves the organization, the knowledge regarding the projects they worked on and contributions made to the organization also leaves with them.

Onboarding & Training

Once the human resources team has selected its candidate and everyone on the team feels comfortable, it's the responsibility of the human resources department to ensure that an onboarding process is in place and followed. The onboarding process should include timely communication with the employees and also an introduction to the organization either through email or instant messaging platforms such as Slack, or Microsoft teams.

The onboarding process should also include the necessary training for a newly hired employee. Including what the company does as a whole, what processes they will own, and an overview of the reporting structure of the company.

This is also a great time for the organization to have the employee review any company policies and gather a signature. A lot of times these processes can be automated with the organization's HR solution. If it's not available then a manual process will have to be completed. The organization can also ensure employees are made aware of basic job responsibilities and processes within the team or department.

Tip - SOC 2 Auditors will pull samples for requested training, it's vital to have this information available for the auditors during the audit period.

Example Training List

1. Company Overview
2. Platform training
3. Security awareness training
4. Software development lifecycle training (SDLC) if applicable
5. Safety Training
6. Financial securities training if applicable

Transitioning positions within an organization

As the business grows, the human resources team will find itself trying to scale a business, and with any new product or service on the market. It will have a tough time finding employees that have the right skills and experience to fill more senior-level positions. With that being said, internal promotions are going to happen.

Sometimes, employees will change departments completely. Just like when a new employee was hired and the human resources team announced it., the human resources team also needs to announce when an employee changes positions. This will allow the employees to be notified but also from a security perspective, reassign processes and roles based upon the job duties of the position.

At a high level, there should be a ticketing system in place that human resource managers submit employee position changes to. On the backend, “ticketing side” there should be a process to re-evaluate the employees' access roles within the environment. Typically the change is completed by the Information Technology department with the addition of more access approved by the manager over the employee. Please see the basic process flow attached below.

Offboarding and Terminations

All companies will face offboarding and terminations at some point. During this phase, even if you're a small startup, offboarding procedures need to be in place. They need to be defined and followed. This is a critical step, as a lot of organizations will not remove access days or even weeks after an employee has been terminated. This is simply because there is no defined process and the lack of communication between Human Resources and Information technology departments did not occur.

Example offboarding procedures

1. Human Resources is notified that an employee is leaving or should be terminated.
2. Human Resources submits a ticket notifying Information Technology to remove access on desired date and time.
3. Information Technology receives requests and plans accordingly.
4. The former employee is termed and access is cut.
5. Communication to the organization notifying departments or teams that the employee has been offboarded.

Annual Evaluation

One of the most critical things for an employee to receive at the beginning, or at the end of each year is their annual evaluation. This is important not only for the employee but also for the organization to continue developing its employees and giving them a chance to bring attention to issues that could be plaguing the organization but not known at the management level.

Not only is the annual evaluation good for both the employee and employer, but it's also a metric used for control within the SOC 2 framework. The annual evaluation can follow any format, as long as they are recorded and the feedback is provided back to the employee.

Organizations that do not believe in an annual evaluation because they have weekly 1:1 sessions are also acceptable. However, you will want to ensure that the managers are maintaining notes and at a high level at least performing yearly reviews that touch base on projects that were completed by the team and the individual contributions made by the employee.

Legal Commitments

Acting as the muscle of the organization and driving it forward, the human resources team will have access to large amounts of data. Typically they are the first to know about terminations, they have access to employee confidential information, and they are obligated to keep it held in strict confidence. Usually by federal and state laws.

This information should be held for safekeeping and following the defined retention periods as permitted by law. Secondly, employees records should also be maintained and updated in accordance with local, state, and federal laws governing that country's jurisdiction.

5.11 Maintenance, Monitoring, and Analysis of Audit Logs

Many times during your career in audit you'll find that organizations if they grow too quickly will be lacking processes to ensure proper maintenance occurs. This is a result of poor processes and procedures.

Maintenance

Just like keeping up with your bicycle or vehicle, maintenance will be required for servers, databases, and code as infrastructure. It's important that organizations perform these actions, oftentimes there are patches required. Updates that need to be applied, or a fix for a zero-day vulnerability.

Defined Maintenance Schedule

Next the organization should have a defined maintenance schedule or "window". Oftentimes this should occur when it will have the least amount of impact on customers.

Example Defined Maintenance Windows

Servers	Databases	Employee Endpoints
Every Month	Quarterly	Weekly
1st Thursday	Last Month in Quarter	Automated Weekly

Lead Implementer Role

Your role as a lead implementer will be to ensure that the organization has defined processes and procedures in place for the maintenance to occur. This should be in the form of a policy at the highest level or at least detailed within a policy. This way there is administrative oversight and control of this process. Something to note here, the organization should also have defined roll-back procedures or a defined process to avert issues caused by maintenance.

Logging Maintenance Activity

A log should be kept with each maintenance activity that occurs. This is important because the service auditors will want to see this if the organization is going from criteria such as availability. This can be used for potential evidence.

Monitoring

Systems errors are a part of life; more often than not, most organizations have experienced a system failure at some point. Have it been in the cloud, or with an on-premise solution. In any case most of the time they were caused by human error for critical parts of the production network, databases, servers, etc. It is important that any organization have monitoring in place. There are many solutions available in the market today, on top of that they are relatively low cost and can provide an enormous benefit when implemented correctly. Often times alerting before issues become critical.

Audit Steps

When reviewing for monitoring, as a lead implementer you will want to see and check for the following.

1. What platform or software is used to monitor the infrastructure.
2. How the monitoring alerts employees "Examples: Text Messages, Emails, Phone Calls"
3. Sample of previous monitoring alerts
4. You can also help determine what should be in scope by reviewing the architecture diagram and critical process flows

Analysis of Audit Logs

You will see that a lot of organizations fail to realize the power of audit logs. Or that they are not keeping them at all, and if they are keeping them, they are usually siloed and stored on that specific system, oftentimes logs are never checked or reviewed. However new technologies called System Incident and Event Management Systems or SIEM for short, allow for the collection and processing of audit logs from multiple sources.

This provides security teams within an organization access to real-time data that before was usually hard to see and very time-consuming to access across multiple systems. On top of that, the correlation aspect of correlating logs between different systems was a very difficult task. However, SIEM technology has

made that possible. Not every organization is going to have a SIEM in place, or afford that luxury. Oftentimes a simple hosted solution that provides similar capabilities within the cloud are also available.

Lead Implementer Role

You will be responsible to ensure that the organization has at the very minimum logging enabled on production and development systems that are within the scope of the system.

This should include but is not limited to;

Example of Log Sources

1. Operating system logs
2. Database logs
3. Application Logs
4. Access Logs

Tip: When reviewing this information, it is imperative that time sources align between each system. Meaning that the time source used for the system should be the same. From operating systems to applications logs. They should always be pulling the time from the same time source. If organizations fail to understand why this is critical, explain to them that in cases where a breach was to occur, it's important that a forensic auditing team be able to piece the puzzle together.

Audit Steps

There are several ways you could audit this. It will vary from organization to organization. However, the key points are outlined below.

1. Is logging enabled for all systems, applications, services, databases that are in scope of the platform or system
2. Review the architecture diagram that has been provided
3. Request a sample of logs from the diagram that outlines applications, services, databases
4. If a SIEM is used, request to see a population of systems that are pushing logs into the SIEM

5.12 Data Breaches and Disclosures

From the previous modules we have learned that you as a lead implementer will be asking the organization a lot of questions around their processes, people and technology. Now we will be discussing ethics around data breaches, data disclosures, and your role as a lead implementer or consultant.

Data has been extracted

We have seen it come across the headlines one too many times. Organizations across the globe face a very real and dangerous threat. The threat of hackers, nation-states, and insider threats. Data breaches, although a common occurrence in today's world, should not be as prevalent as they are. If organizations have the right technology in place and have proper procedures in place, you would not see as nearly as many breaches.

To help limit exposure, the controls we have talked about throughout this module should assist organizations from facing a serious breach. Although there are more to come, It starts at the top. You as a lead implementer need to ensure both the technical and business controls are in place.

Example of Controls-

1. Ensuring Policies are in place
2. Eliminating Risks
3. Remediating Risk
4. Data Classification
5. Asset Mapping
6. Insurance

However, there will come a time when an organization is breached and they need to be prepared. You will need to walk the organization through a tabletop exercise. As this will help them identify potential process weaknesses. Part of this exercise should include a breach where the hacker(s) have exfiltrated data out of the network, your job will be to run point on the simulation and ask key questions. Build the scenario around the organization, but use your imagination and creativity.

Table Top Questions=-

1. Is there a defined communication plan
2. If yes, where is it? Who do we contact?
3. Can they identify the data that was breached
4. Can customers be identified that were affected by the breach?
5. Have the assets that have been breached been identified?
6. Are the logs available?

Cyber Liability Insurance

Many times organizations that have cyber liability insurance will have resources available during, and after a breach. Be sure to request a copy of the policy to help address questions and provide a defined playbook for the organization that you're working with.

Examples of Coverage that is included for Cyber Liability Insurance

1. Public relations communications
2. Incident response resources
3. Assistance for recovery and business continuity

Audit Steps-

1. Perform a tabletop exercise
2. Notate deficiencies during the exercise
3. Assist the organization in the creation of a data breach playbook
4. Ensure defined roles are known to all parties
5. Ensure the playbook is updated yearly

Data Disclosure-

We all know organizations share data, buy or sell our data. We have seen this occur with social tech giants like Facebook, now known as Meta, Google with their advertising and tracking ids. However many companies also buy and sell our data or share it with their partners.

They do this for multiple reasons. The most common being it provides organizations monetary value or for data enrichment purposes. With that being said, it's important to know the following.

1. Does the organization sell its customers' data?
 1. If yes, to whom?
2. Are customers made aware that this behavior occurs?
3. Does the data disclosure list the companies it provides data with?
 1. If not how does the company define the term "Parties or Third Parties"

Audit Steps

1. Audit the privacy policy
 1. Does it outline the data the platform captures and processes?
2. Are Data Processing Agreements "DPA's" in place with contracts?
 1. You will need to pull a list of contracts and DPA's
 1. Important Note - DPA's are not always needed
3. Review a sample of that data that was sold, or provided to a third party.
 1. Do the data fields align with what is defined in the data disclosure?
4. Ask for a population of third parties the data was shared with.

5.13 Crisis Management

When the organization isn't being attacked and or a breach occurs. The organization will face another threat. The threat of a crisis.

What is a crisis - Well to make things simple, a crisis is when something has gone terribly wrong. From our perspective, we will keep things simple and use the following example.

Example

Roger, who is a systems engineer, arrived at work to find that a critical application hosted in the cloud production environment went down overnight. Neither he nor his team was notified of the incident, and today during normal business hours they are losing 1.2 million dollars per hour. The system has already been down for over 12 hours. The business has had an estimated loss of 13 million dollars since the crisis began. Things are getting heated at corporate, the executive team is furious as to what has unfolded, enormous pressure from management has compounded. The hallways are filled with yelling and screaming between managers protecting their employees and executives who report to the board of directors.

After reading the example above you can see where proper planning and cooler heads would have prevailed in this situation. However, not every organization is going to be like this.

You as a lead implementer will be responsible for ensuring that the organization has a defined crisis management plan. The plan at a minimum should encompass the following processes.

Crisis Management Plan Processes-

1. Communication to employees during a crisis
2. Communication to customers, partners, and vendors-
 1. How will the communication occur? Social Media?
3. Process for recovering after a crisis
4. Notification after the incident
5. Performing a Post Mortem "Root Cause Analysis"

For organizations that already have a defined crisis communication plan, review it with them. Ensure that key stakeholders are called out by title. Roles and responsibilities should be defined and known to all applicable parties. Last but not least ensure that a root cause analysis is performed, and lessons learned follow-up occurs after.

5.14 Segregation of Duties and Least Privilege

The more people, the less you have to worry about. The fewer people the more you have to worry. This phrase rings true with smaller-sized businesses. Where multiple different people wear different hats.

What is Segregation of Duties?

Segregation of duties is where the "people" performing the processes inside of the business do not have full control over anyone activity that could be detrimental or cause significant harm to the business.

Let's take, for example, Joe. Joe is a programmer who was hired when the company was first getting started. Since Joe was an early employee, he enjoyed many access rights from the beginning. Many of which still exist today. Joe one day decides that he's not being compensated fairly. Joe is of the entitled mindset, and since Joe thinks he is smarter than everyone else and has been there long enough, starts plotting his retirement dreams in the Cayman Islands.

Joe immediately gets to work, sets up offshore bank accounts, and starts embezzling money.

After a few months, the business notices that some transactional data is off. The numbers just don't add up. From these findings an internal investigation was launched with an independent third party. They find that there were significant code changes within the last 6 months and that is why the transactional data is off.

From this example above, you can see why segregation of duties is important. The people who approve the code, should not be the ones that write it. If you are a lead implementer with Scytale, we have these processes baked into our platform. However if not, you will have to perform the following.

Auditing Steps

1. Interview and understand critical business processes
2. Review Access rights of employees of critical business processes
3. Perform sample and population pulls for critical business processes
4. Report deficiencies
5. Notate findings
6. Perform Remediation

Your role as a lead implementor will be to ensure that the business has documented these key roles and processes and that employees within the organization have at least a two-man rule applied for critical business processes such as code changes, architectural changes, and transactional changes.

Least privilege

This brings us into the principle of least privilege. This is when a user has the minimum amount of privileges needed to perform his/her work. This also applies to users that would normally need elevated privileges such as IT administrators or system administrators.

For smaller teams, this is very hard to implement and maintain. Although, very disciplined teams can manage this set of procedures and processes. Ensure that that organization has a defined access matrix from provisioning access to systems and services.

Audit Steps

1. Pull a listing of all employees that have access rights
2. Pull a list of all access groups that are defined
 1. Determine what level of access each access group provides
3. Pull a sample of job descriptions and perform interviews to determine if employees potentially have too much access.
4. Alternatively if the organization has a role-based access matrix, you can use this as a guide.

5.15 Change Management

Every organization, no matter what size, should have a proper change management process in place. Changes to any system should be controlled throughout the lifecycle of the system and components. The change management process can be generally broken down into the following aspects:

- A change management policy and procedure document should be in place that describes the whole change management process.
- A change methodology should be adopted by management i.e. Agile or devops.
- A ticketing system should be considered at the Organization, in order to log, classify, track, document, manage and keep evidence of the change e.g. Evidence of testing can be uploaded and linked to a specific ticket.
- All changes should be discussed, analysed and prioritized prior to being developed.
- A process should be in place on how changes are designed and developed.
- Responsibilities in the change management process should be segregated as below:
 - Develops the change
 - Test the change
 - Implements the change
- Developers cannot have access to production. If its a small environment, than access should be monitored or a process should be in place where temporary access is given for developers to work on production or to implement the change.

- Testing strategies should be formalized and implemented. All changes should ideally be tested prior to implementation. This includes functional testing, UAT testing, QA testing etc.
- All changes must be approved and authorized prior to implementation. This should be a formal sign off or authorization on a ticketing tool. This is normally a key piece of evidence for the auditors.
- An emergency change process should also be implemented and clearly defined in the change management policy.
- Separate environments of a system should exist:
 - Development environment
 - QA/ test environment
 - Production environment

The above is not a conclusive list of how a change management process should look like, but these are the key elements.

Audit Steps

1. Select one change and perform a walkthrough with management, so that the auditors can get an understanding of the change management process.
2. Pull a listing of changes for the period of review from the ticketing tool or the system itself
3. Select a sample of changes and request the following evidence:
 1. Evidence that the change was tested.
 2. Evidence that the change was approved.
 3. Evidence that the developer and the implementer of the change were different people.
4. Screenshot showing the different environments i.e. DEV, QA and PROD.
5. Pull a list of developers and compare with a list of prod users and also with a list of user roles who have access to make changes in PROD.

5.16 Internal Audit

Internal Audit teams are few and far between, and usually, if an internal audit team does exist, they mainly just focus on financial controls and oversight. It's very rare that you will see an internal audit team that performs both financial and information technology compliance audits. Usually, this is only performed in consultation with third parties.

Many organizations you work with especially in start-up land will not have an internal audit team. Your duty as a lead implementer will however focus on getting the organization to consider or delegate duties for compliance activities. After all, in module one we discussed that management needs to set the tone at the top and provide the necessary tools and availability to ensure a successful audit.

Tip: For the people that are performing the internal audit, these can not or should not be the same people that have access to change system results, manipulate data, or have the ability to conceal it. The team or individuals should also have a different reporting structure.

6. Initiating a SOC 2 Audit

6.1 Audit Principles and Concepts

There are quite a few auditing principles and concepts that might seem foreign to management or perhaps even an inexperienced service auditor. Below are some basic definitions that will be commonly used throughout a SOC 2 audit and mentioned in the SOC 2 report:

Principle/concept	Description
Carve-out method	Method of dealing with the services provided by a subservice organization. The nature of the services performed by the subservice Organization is included in section 3, but the relevant related controls are excluded. These controls are also excluded from the service auditors scope, hence the concept “carve-out” meaning: The subservice Organization’s controls are carved out from scope.
Inclusive method	Method of dealing with the services provided by a subservice organization, but now the subservice organization controls are included in section 3 and are tested by the service auditor.
Complementary user entity controls (CUEC)	CUECs are controls that reside at the user entity level of a service organization. User entities are organizations that utilize the services of a service organization.
Controls at the service organization	Controls over the achievement of a criteria that is covered by the service auditor’s assurance report (SOC 2).
Controls at a subservice organization	Controls at a subservice organization to provide reasonable assurance about the achievement of a criteria.
Service auditor	A professional accountant in public practice who, at the request of the service organization, provides an assurance (SOC 2) report on controls at a service organization.
Service organization	A third-party organization (or segment of a third-party organization) that provides services to user entities that are likely to be relevant to user entities’ control environment.
Description of the system (Section 3)	The policies and procedures designed and implemented by the service organization to provide user entities with the services covered by the service auditor’s assurance report (SOC 2). The service organization’s description of its system includes identification of: the services covered to which the description relates, IT elements, relevant Trust Service Criteria, and related controls.

Subservice organization	A service organization used by another service organization to perform some of the services provided to user entities that are likely to be relevant to user entities' control environment.
Population	The number of occurrences that a control was performed i.e. If there were 100 users terminated which required a signed off boarding form, then the auditors population for testing terminated users will be a 100.
Sampling	A number of instances to test the operation of the control (sample) is normally selected from the population. The auditor will have a sampling methodology that stipulates the number of samples that should be selected, based on the population of the control. For example, the auditor would select a sample of 5 from a population of 100 terminated users, based on the auditors sampling methodology. Management would then need to provide evidence for the 5 selected sample of terminated users.
Design of a control	Auditors will look at the design of the control and consider whether the control is capable of effectively preventing or detecting and correcting a specific risk. The auditors will also look at the factors or characteristics of the control that are most important to its effectiveness. The extent of this evaluation is a matter of professional judgment and will vary based on the complexity of the control.
Implementation of a control	Auditors will look at whether the control is implemented as designed. This means that auditors will select a sample of instance and require evidence to corroborate the design of the control. In most cases, the auditors will perform a walkthrough of the control when testing the implementation of the control.
Operating effectiveness of a control	Auditors use this term to determine whether a control was functioning as intended for a period of time i.e., the control was operating effectively throughout the period 1 January to 31 December. This conclusion is based on the sample that the auditor would select to test the operating effectiveness of a control. For example, the auditors tested the sample of 5 terminated users and the evidence provided for all 5 users were deemed appropriate to conclude that the control was operating effective. Should 1 of the 5 samples fail for whatever reason, the control would be deemed ineffective i.e. the control was NOT operating effectively throughout the period 1 January to 31 December.
Type I	A type I audit indicates that the auditor will only test design and implementation of the controls provided by management at a point of time.
Type II	A type II audit indicates that the auditor will test design and implementation and operating effectiveness of the controls provided by management over a period of time (6 to 12 months).

Information produced by the entity (IPE)	IPE is information that the auditors use to understand the entity and its environment, to perform procedures, to test a control upon which they intend to rely, or information used by entity personnel to perform a control. Some IPE may be generated using the entity's IT systems. For example: • Standard "out of the box" reports as shipped with an application system that have not been modified and do not allow for customization of inputs/outputs, like a user listing from SAP.
--	--

6.2 Preparation of Audit

Before an audit can be conducted, the service organization and its management team must commit to the extensive requirements that are required for a SOC 2 audit. This is the first step in that process. Once the organization's management team is onboard, the next logical step is to review the system and determine if any potential major gaps exist. If they do, then it is best to start to proactively identify those and report it to the management team for remediation.

In an earlier chapter we provided an overview of the audit lifecycle. For the rest of the steps, please refer to that diagram.

Along with providing the auditors with a description of its system (Section 3), management also needs to provide the auditors with a management representation letter that:

- Reaffirms the assertion accompanying the description of the system;
- That it has provided the auditor with all relevant information and access agreed to; and
- That it has disclosed to the auditor any of the following of which it is aware:
 - Non-compliance with laws and regulations, fraud, or uncorrected deviations attributable to the service organization that may affect one or more user entities;
 - Design deficiencies in controls;
 - Instances where controls have not operated as described; and
 - Any events subsequent to the period covered by the service organization's description of its system up to the date of the auditor's SOC 2 report that could have a significant effect on the auditor's SOC 2 report.

The management representation letter will be in the form of a letter that is addressed to the auditor. The date of the letter will be as near as practicable to, but not after, the date of the auditor's SOC 2 report.

Understanding the objectives to be achieved

It is important to understand what objectives need to be achieved, for an organization to be SOC 2 compliant. The criteria and the controls that support the criteria will effectively drive the outcome of the objectives. Failing any of these objectives will result in a qualified opinion, which in essence means the Organization is not SOC 2 compliant.

These objectives are standardised and will be the same for all organizations that want to achieve SOC 2 compliance. These objectives are also noted as part of Section 1, which is the auditor's opinion:

- To obtain reasonable assurance about whether, in all material respects, based on suitable criteria:
 - The service organization's description of its system fairly presents the system as designed and implemented throughout the specified period;
 - The controls related to the criteria stated in the service organization's description of its system were suitably designed throughout the specified period; and
 - Where included in the scope of the engagement, the controls operated effectively to provide reasonable assurance that the criteria stated in the service organization's description of its system were achieved throughout the specified period. (This objective is excluded from a Type I report).

The above objectives are written exactly the same in Section 1 in the SOC 2 report. You as the lead implementer need to make sure that these objectives are achieved. The system description needs to accurately and completely describe the IT environment that encompasses security, availability, privacy, processing integrity and confidentiality (depending on what Trust Service Category has been selected).

6.3 Trust but Verify Approach- Audit Evidence

Currently a SOC2 audit process uses the trust but verify approach by external auditing teams. The theory behind this approach is that the auditing team receiving the evidence produced by the service organization is forthright and not tampered or altered with. This approach allows for the auditing team to stay independent of pulling the evidence. Evidence is obtained from management at three various stages of the audit:

1. Obtaining Evidence Regarding the Description

The auditor will obtain and inspect the system description and will evaluate whether those aspects of the description included in the scope of the engagement are fairly presented i.e. the way we describing our system is actually the way it is working. You can't say we use JIRA for change management, and then JIRA is still being implemented. The following are the checks on the system description that the service auditor will perform:

- Controls stated in the service organization's description of its system do address the criteria;

- Controls identified in that description were implemented;
- Complementary user entity controls, if any, are adequately described; and
- Services performed by a subservice organization, if any, are adequately described, including whether the inclusive method or the carve-out method has been used in relation to them.

The auditor shall determine, through other procedures in combination with inquiries, whether the service organization's system has been implemented. Those other procedures shall include observation, and inspection of records and other documentation, of the manner in which the service organization's system operates and controls are applied.

2. Obtaining Evidence Regarding Design and Implementation of Controls

The auditor will decide which of the controls at the service organization are needed to achieve the criteria (For example what controls are in place to achieve the Control Environment criteria) and shall assess whether those controls were suitably designed.

To ensure that controls are suitably designed, the auditor will perform the following procedures:

- (a) Identifying the risks that threaten the achievement of the criteria; and
- (b) Evaluating the linkage of controls identified in the service organization's description of its system with those risks.

When designing and performing tests of controls, the auditor will:

- Perform other procedures in combination with inquiry to obtain evidence about:
 - How the control was applied;
 - Does the control address the criteria;
 - The consistency with which the control was applied; and
 - By whom or by what means the control was applied;

Evidence pertaining to the implementation of the control, shall be obtained via walkthroughs performed between the auditor and management. A walkthrough is a process where the auditors will "walk – through" a control in order to obtain an understanding of how the control operates. During this walkthrough process, the auditor will obtain evidence in forms of screenshots, emails, documentation etc. in order to verify that the control was implemented as designed.

Control design: For example, users gain access to Windows via a completed and signed IT form.

The auditor will enquire of management to take them through one such example of a user gaining access to Windows i.e. the walkthrough. Should the auditor see that users are given access to Windows via a completed and signed IT form, then they will conclude that the control is implemented as designed. If users are given access to Windows via a completed IT form that is not signed, then the auditors will conclude that the control is not implemented as designed and the control will fail.

Design and implementation of the controls are normally tested together. At this stage it is important to clearly show the auditors that the controls management have in place, are implemented as management say they are. Management cannot say that they have an anti-virus installed on all end users laptops and then the first laptop that is checked the auditors find that the anti-virus software is not installed. Failing a control on design and implementation, is a much more significant deficiency than failing a control on an operating effectiveness level, which is discussed below.

3. Obtaining Evidence Regarding Operating Effectiveness of Controls

When providing a type 2 report, the auditor shall test those controls that the auditor has determined are necessary to achieve the criteria stated in the service organization’s description of its system (Section 3) and assess their operating effectiveness throughout the period. This needs to be a period no less than 6 months and no more than 12 months.

As per number 2 above, the auditor tested the design and the implementation of the control, which is a sample of one occurrence. When testing for operating effectiveness the auditor needs to select a sample throughout the period and obtain evidence for the sample to ensure that the control was operating effectively throughout the period of testing.

When determining the extent of tests of controls, the auditor shall consider matters including the characteristics of the population to be tested, which includes the nature of controls, the frequency of their application (for example, monthly, daily, a number of times per day), and the expected rate of deviation. For example if we have a population of 50 new users that were added to AWS for the period 01 January to 31 December, the auditor would select a sample of 5 new users and request the relevant evidence for those 5 users.

Evidence provided for the sample selected, can range from screenshots, emails, documentation etc. In essence the evidence provided needs to clearly indicate that the control is being performed as designed over a period of time. In the day and age where almost all the evidence will be electronic, it is important that the pieces of evidence have a date stamp on. Evidence that does not have a date stamp on, can provide difficulties for the auditor to determine the validity of the evidence.

Evidence obtained in prior audits about the satisfactory operation of controls in prior periods does not provide a basis for a reduction in testing, even if it is supplemented with evidence obtained during the current period. This means that the evidence provided needs to be from the current period of review.

6.4 Types of Audit Procedures Performed

Testing will occur for different criteria and controls that have been implemented by the service organization. For example, the testing and evidence for availability will be different than that of privacy. As a lead implementer or consultant, you should know the types of test and evidence that correspond to the evidence that needs to be produced. The table below provides a basic breakdown of the types of tests that would be performed on any given control:

Test	Description	Practical Examples
------	-------------	--------------------

Inquiry	Conducted detailed interviews with relevant personnel to obtain evidence that the control was in operation during the report period and is accompanied by other procedures noted below that are necessary to corroborate the information derived from the inquiry. This procedure is normally performed by the auditor to obtain an understanding of the design of the control.	During the walkthrough with management, the auditor will ask management (inquire) to explain how users are given access to AWS.
Observation	Observing the performance of the control multiple times throughout the report period to evidence application of the specific control activity.	During the walkthrough with management, the auditor will observe management creating a test user and observe the test user being given access to AWS. Furthermore, the auditor will observe the authorization of an existing user, and verify the completed access form that is signed by the relevant manager. This observation will be documented in the auditors working paper.
Examination of documentation / Inspection	If the performance of the control is documented, inspected documents, screenshots and reports indicating performance of the control.	The auditors will select a sample of new AWS users and inspect the relevant evidence received i.e. signed access form. The evidence received will be compared with the control that was provided by management.
Reperformance of monitoring activities or manual controls	Obtained documents used in the monitoring activity or manual control activity and independently reperfomed the procedures. Compared any exception items identified with those identified by the responsible control owner.	The auditor will obtain a list of AWS users and compare it to a termination listing or an HR listing to verify: (1) Terminated users are removed from AWS (2) The active users access is appropriate based on their job responsibility. E.g. the receptionist wouldn't need AWS access. In essence, the auditor reperfomed the user access review control.

6.5 Documentation

The auditor needs to prepare documentation (also called the auditor working papers) that is sufficient to enable an experienced auditor, having no previous connection with the engagement, to understand:

- The nature, timing, and extent of the procedures performed to comply with SOC 2 and applicable legal and regulatory requirements;
- The results of the procedures performed, and the evidence obtained; and
- Significant matters arising during the engagement, and the conclusions reached thereon, and significant professional judgments made in reaching those conclusions.

The auditor also needs to document discussions of significant matters (this include deficiencies, possible reasons for a qualified opinion, lack of evidence etc.) with the service organization and others including the nature of the significant matters discussed and when and with whom the discussions took place.

The auditor shall assemble the documentation in an engagement file and complete the administrative process of assembling the final engagement file on a timely basis after the date of the service auditor's SOC 2 report.

7. Monitoring, Control, and Completing SOC 2 Project Plan

7.1 Automation of Controls

Anytime an organization is laying out a control framework, they will start to understand the complexities of pulling in all of the necessary information together in order for the audit team to connect the dots, reconcile the data and then finally achieve the audit results. It's a huge undertaking, and from a resource perspective, the organization will see the man hours required.

There is another alternative solution that companies have been performing over the last few years, and that is automation. Automation of collecting evidence, splicing data, and formatting it so that little human time is used during this process.

If you're a lead implementer with Scytale, you're already aware of the benefits our platform provides when automating the collection of evidence and producing the reports for the auditors. This saves copious amounts of time and resources from the organization.

However, if you're a consultant outside of Scytale and you're not using the Scytale platform, you could assist the organization with automating the collection of evidence. This will likely incur a huge cost for the organization and then also additional cost to maintain and support the automation that has been built. Alternatively, you could automate smaller processes and procedures so that it does provide so time back during the audit period. In any case, if this is the goal, it may be best to check out platforms that provide this type of collection.

7.2 Real-time Identification of Non-Compliance Issues

During an audit period, if automation is not being performed and the collection of evidence is not automated. You will need a team of internal compliance analysts to analyze your compliance data and spot deficiencies within your compliance program. This is absolutely necessary when trying to maintain an unqualified audit opinion.

Otherwise what will most likely happen is that after the first audit period, people will start to become comfortable, and the collection of evidence and internal review will start to slip, or worse you have lazy compliance professionals that wait until the last second to collect the evidence and then remediation almost always becomes impossible. This is actually more common than you might think, tons of organizations perform well in their first audit period, and then when it comes to the second round of audits, they fail or have a lot of findings.

This will lead to not getting identified in real-time of what needs to be addressed especially when it comes to determining if a compliance issue needs to be corrected.

Most common issues that need to be addressed

1. Endpoints need agent for malware or endpoint management

2. Active accounts even after termination
3. Patches have not been deployed to all endpoints
4. User access reviews not being performed
5. Inadequate Password policies
6. Developer access

7.3 Response and Records of Non-Compliance Issues

Regarding the section above, we talk about the identification of non-compliance issues and how they typically start inside an organization. From that perspective, we are now going to discuss the response and records on non-compliance issues.

As compliance professionals inside the organization, the management team should be tracking its compliance objectives and outputs through project completion. However, there is a difference between being non-compliant and being negligent.

Organizations that have undergone a successful SOC 2 audit in the past may feel the burden of an employee leaving the organization that previously filled the role as a lead implementer.

If an organization is under scrutiny from multiple deficiencies found by an auditing team, the organization's management team will have the option to address or rebuttal their concerns in what is known as the management's response within the final report. This is done after an opinion has been provided and before a final published copy of the report is shared with customers.

8. Conducting a SOC 2 Audit

8.1 Communication During An Audit

During an audit period, as a consultant or lead implementer, it will be necessary to work functionally across different departments within the organization. An example of departments that you will most likely be working closely with is listed below.

1. Human resources
2. Information technology
3. DevOps / Engineering
4. Executive Level
5. Information security
6. Board of Directors
7. Marketing

Depending on the organizations' size and structure this could change however the list above is a good starting point. During the course of an audit, you will need to address and execute on communication regarding timelines, evidence collection, and gaps found. Which in turn will require new controls to be implemented and new processes developed most likely.

It will be your responsibility as a lead implementer to ensure that the communication regarding these new processes and procedures is known to all parties and documented for the organization.

Communication with auditors:

You will also be responsible for communicating controls or additional evidence requests from the auditors. This is a big responsibility as getting the correct evidence could mean the difference between a delayed or successful project timeline.

Communication with executive team:

However, your communication will not stop with the auditors or departments within the organization. You will need to provide the executive level team with updates regarding the status of the attestation. Most importantly, you must be able to communicate potential gaps/findings that could negatively affect the opinion statements provided by the auditing firm and get those remediated as quickly as possible.

8.2 Audit Procedures and Evaluation of Evidence- Auditors' Point of View

Once an audit period has been set with the audit team and the organization. It will be your responsibility as a lead implementer or consultant to ensure that you gather the audit timelines and procedures for

the auditing team. This is vital as service auditors do not have to accept an engagement if they feel that the team members inside the organization do not have the knowledge base to assist.

Example Audit Procedures (High level)

1. Gap analysis performed
2. Remediation if necessary
3. Firm Selected
4. Audit dates set
5. Audit begins
6. Evidence collection through audit period
7. Evaluation of evidence collected (internal)
8. Submission of evidence
9. Evidence reviewed by auditors
10. Opinion provided

The above list is not meant to be exclusive but to provide you a high level of what is going to occur from the start of an organization's SOC 2 attestation through the end of the audit period.

Some organizations will not have an internal audit function, you as a lead implementer or consultant should view this as an opportunity to review the evidence collected on behalf of the organization.

Although this will result in more hours billed to the organizations, it is a vital step and a great opportunity cost for you.

8.3 Drafting Audit Plans

Just like architects design buildings. Lead implementers will need to be familiar with project planning skills. Drafting audit plans is nothing more than laying out the whole audit process on paper, and revising before coming up with a solution that meets the organizations' timelines as well as the auditors.

Example

To assist with this process, it's best to take the common control criteria and lay them out along with each control in a spreadsheet. This will provide you with a base of what is to be expected during the audit period. Next, you will want to take that information and match each control to the expected output for the control. For example, if the organization is being tested on availability, it may want to see a list of outputs from the regions and availability zones listed inside of the organizations' cloud service provider.

8.4 Audit Findings and Deviations

Auditors for a long time have been paid on the number of findings or deviations that they typically have found. They already have the tools and knowledge on how to find these deviations and generally speaking, they should have metrics based upon the organizations' size to determine if something is wrong.

After the audit period has ended and the organization has submitted its evidence, the auditing team will have two or more people comb through the evidence requested and start analyzing it.

During this time either the auditing team will come back with the following:

1. More questions and request additional information.
2. Write up a finding.
3. If the evidence is sufficient and the control is designed properly they will move on.

If audit deviations are found, this will negatively impact the organizations' SOC 2 attestation report, resulting in a qualified, disclaimer or adverse opinion.. This is why it is critical to have the internal teams review the evidence and ensure that controls are constantly operating effectively. Once the deviations have been notated they will be placed alongside the controls in the report and given a status of either no exceptions noted, or it will provide reasoning as to why that control failed. These will be listed under the column titled results of service auditors test of controls.

9. Closing the Audit and Follow-Up

9.1 Audit Closing Procedure

Once the audit has concluded. You should be notified by the auditing team that the audit review has ended and the organizations' report should be finalized within the next 2 to 4 weeks. Although this may seem like a long time, in reality. The organization needs to be preparing for its next audit cycle.

After the auditors have finalized the review of evidence and provided their opinion they will send over the final report for the organization's management team to review. During this time, it is best that the organizations' management sit down and review it individually first, and then collectively as a group.

9.2 Organizing a Closing Meeting and Stating The Conclusion of The Audit

Once management has had time to review the report, it will be time to set up a closing meeting with the auditors. Most of the time, the organizations' management team should have a list of questions readily available for the auditors.

Who should attend this meeting?

If deviations were found by the auditing team, it would be best to have that department's manager sit in and discuss potential shortcomings that were found. This will provide a line of communication between the organizations' management team, the auditors, and the manager of the department of where the deviation was found.

9.3 Auditors Opinion Results

Upon inspection of the final SOC 2 report you will notice that the auditors have added additional information. If deviations are found regarding controls, those will be notated in the controls section.

At the beginning of the report, the auditors will also provide more information regarding their opinion. There are four opinion options that auditors can provide, they are as follows:

1. Qualified
2. Unqualified
3. Disclaimer of opinion
4. Adverse Opinion

A qualified opinion is when the auditing team can not determine if the controls designed are operating effectively. An unqualified opinion is when the auditors have determined that the controls are well designed and operating effectively. Disclaimer of opinion is when the auditing team could not obtain sufficient evidence that the controls were in place and operating effectively. Adverse opinion means that the auditing team has found multiple controls that have not been designed properly and are failing.

9.4 Deviations and Management's Response

After the audit period has ended and the audit team issues the organization a preliminary report, the organization's management team will be given time to review it and provide what is known as a management's response. It should be noted that management does not have to provide a response, however if there are deviations or if a control changed and the a control was deemed not operating effectively, then this is the opportunity for a management rebuttal as to the reason why.

9.5 Complementary User Entity Controls (CUECs)

Complementary User Entity controls are controls that fall on the user entity. Essentially what it means that there is a shared responsibility between two parties to ensure control criteria is being achieved. Think of CUECs as more of controls that need to be performed on the customer's end of the service being provided.

Example

UI Automation Co. - User Interface Automation Co, is a company that provides UI automation with a computing platform, think Mac OS X and Windows Operating Systems. They automate against native applications within a computing resource. However they provide an online platform that users can login to and see the processing of UI automation jobs, completeness of jobs and a big red emergency stop button that will stop the automation.

Now let's introduce a company that utilizes UI automation SaaS offering. This company is called Green Money Processing Inc. Green money uses UI automation Co. to assist with processing data between older systems that do not have an API backed. However, Green Money just fired an IT developer. The developer was very distraught and upset about being let go. Since the developer worked on setting up the automations, and knows the username and password to the online service for UI automation, they decided to delete all of the automations they set up for Green Money. This would be an example of a CUEC that should be defined and spelled out in UI Automations SOC2 report.

Now granted, in a perfect world, UI automation would have single sign on implemented as an authentication factor. However, not all services organizations are going to have single sign on implemented, especially during its early stages.

9.6 Sub Service Organizations Carved Out Controls

Organizations that have a defined scope and controls that operate outside of the audit scope, will be eligible to have those controls excluded from the audit report. Typically these are internal controls for a particular business unit or processes that do not affect the overall system. These controls will need to be discussed with all parties before the audit project is underway.

9.7 Corrective Action Plans For The Following Audit Cycle

Once the organization has received its final report and the audit period is officially over, is a great time to organize the lessons learned and recap on processes and controls that went well during the audit and in retrospect the processes that didn't go so well.

To perform this exercise, invite all key stakeholders that were involved in the audit process and walk them through each of the control criteria that the stakeholders were responsible for, recap on any deviations if they were found by the auditing team and notate if a process needs improved or if a technical issue needs to be resolved.

9.8 Marketing Aspects and Logo Use

Marketing

During the audit period there is a lot of communication between key stakeholders throughout the organization. While at times things can become stressful and frustrating. It's important to maintain those relationships and build trust. One relationship in particular that needs to be built is with the marketing department.

The marketing department will be instrumental in helping other businesses understand that the company has been audited by a third party and that an attestation report is now available. Using social media and spreading awareness regarding the company's success and compliance efforts can also lead to bigger customers who could have overlooked the organization previously because they have stringent security controls in place.

Logo Use

Once the organization has successfully received its attestation report and the audit period has closed, the organization can then start using the ACIPA SOC II logo in regards to its marketing material. Creating awareness is a big factor for your customers.

Glossary-

Gap analysis - is an assessment of an organization's current processes, procedures, and technology for the purpose of identifying the differences between your current state and future state.

Risk assessment - Process of evaluating the potential risks that may be involved in an activity, Information System, or platform.

CIA triad - A model for guiding policies, and control categories for an organization. Also referred to as the AIC triad as not to get confused with the Central Intelligence Agency.

AICPA - American Institute of Certified Public Accountants is the national professional organization of Certified Public Accountants in the United States.

Audit - An external examination of an organization's security posture or financial statements by an internal team or third party.

SOC 2 - Voluntary compliance standard and a report on controls for services organizations that provide services for both on-prem and cloud solutions.

Vulnerability scanner - A piece of software or hardware device that identifies security weaknesses and flaws in information systems and software.

Source code analysis - Automated testing of source code for the purpose of finding vulnerabilities, or security weaknesses within the codebase before they are released to production.

Multi Factor authentication (MFA) - Authentication mechanism that requires a minimum of two inputs from a user. (Something you know, Something you have, Something you are)

NIST - National Institute of Standards and Technology

Deviation - A difference between a set measurement and expected outcome value or variable.

Compensating control - A process, software, or hardware device that is put in place to counteract a threat or security weakness for the sole purpose as it would be too difficult to implement a mitigating control.

Audit scope - Boundaries of the platform or systems that encompass a platform or service. Including policies, procedures, and processes.

Anti-Malware - A widely used technology to prevent, detect and remove many categories of malware, including computer viruses, worms, Trojans, keyloggers, malicious browser plug-ins, adware and spyware

Technical Control - A control type that is covered under a technical system or device.

Examples - Anti-malware, System Incident Event Management System.

Procedural Control - A process in which employees or software performs an action to achieve the desired result. Examples - User access review, Annual policy updates, Endpoint compliance reviews

Administrative Control - A guideline that a business or business unit publishes in order to comply with compliance objectives, or the law. Examples - Company policy, Code of conduct.